

Core Skills for SOC Analysts

Tracy Wallace

Cloud Architect, Cloud Security Engineer

IT Trainer since 1995

Senior Instructor - Certifications, Security, AI & Cloud @ INE

KEY CONCEPTS

- **Security fundamentals & defense strategies**
- **Network & system visibility**
- **Log analysis & alert triage**
- **Analyst mindset & critical thinking**

MAJOR TOPICS

- Threats, attacks & risk concepts
- Networking fundamentals & secure architectures
- Windows & Linux operating system basics
- Analyst thinking, compliance & data handling



LEARNING OUTCOMES

- Understand how modern SOC's operate
- Analyze logs & network traffic effectively
- Identify & triage security alerts
- Communicate findings clearly & accurately

PREREQUISITES

- Basic computer literacy
- General interest in cybersecurity
- No prior SOC experience required

LET'S GO!

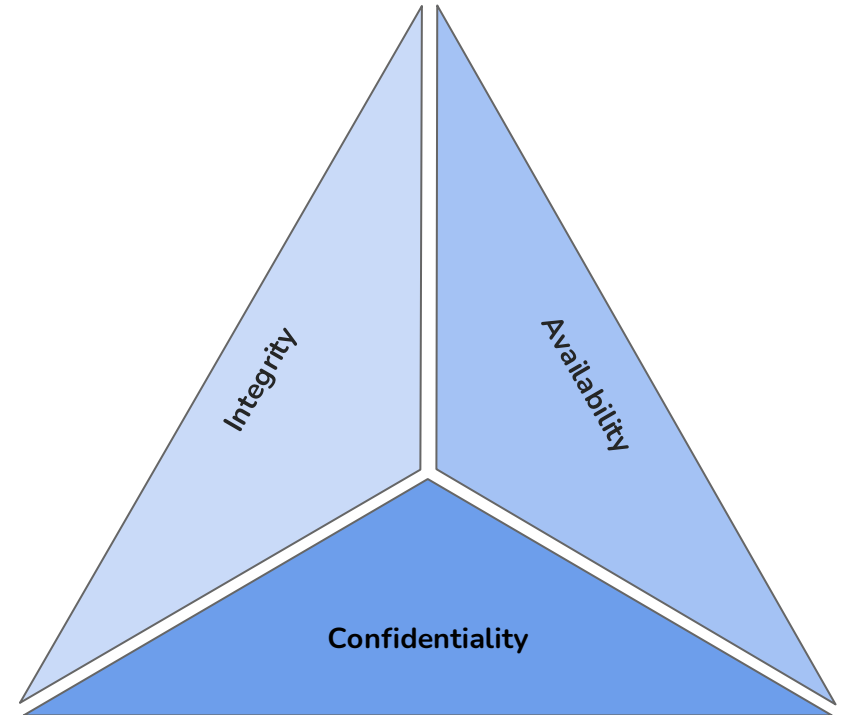


What is Information Security?



Definition of Information Security

- + Information Security (InfoSec):
The practice of protecting information from unauthorized access, use, disclosure, disruption, modification, or destruction.
- + It applies to data, systems, networks, people, processes



Why Organizations Need InfoSec

- + Increasing cyber threats and attack sophistication
- + Protection of sensitive data (financial, personal, intellectual property)
- + Legal, compliance, and regulatory requirements
- + Operational continuity and business reputation

InfoSec in Practice



Governance, Risk, & Compliance



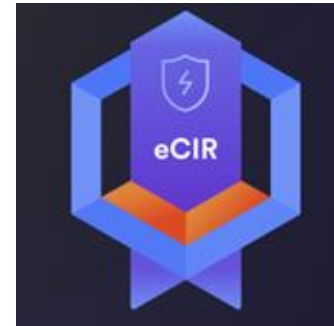
Preventative & Technical Controls



Monitoring & Detection



Training & Awareness



Incident Response & Recovery



The Role of SOC Analysts

- + SOC analysts help enforce information security by:
 - + Monitoring systems for signs of attack
 - + Investigating alerts and suspicious events
 - + Escalating incidents when needed
 - + Helping ensure confidentiality, integrity, and availability

What is Information Security?



Defense in Depth

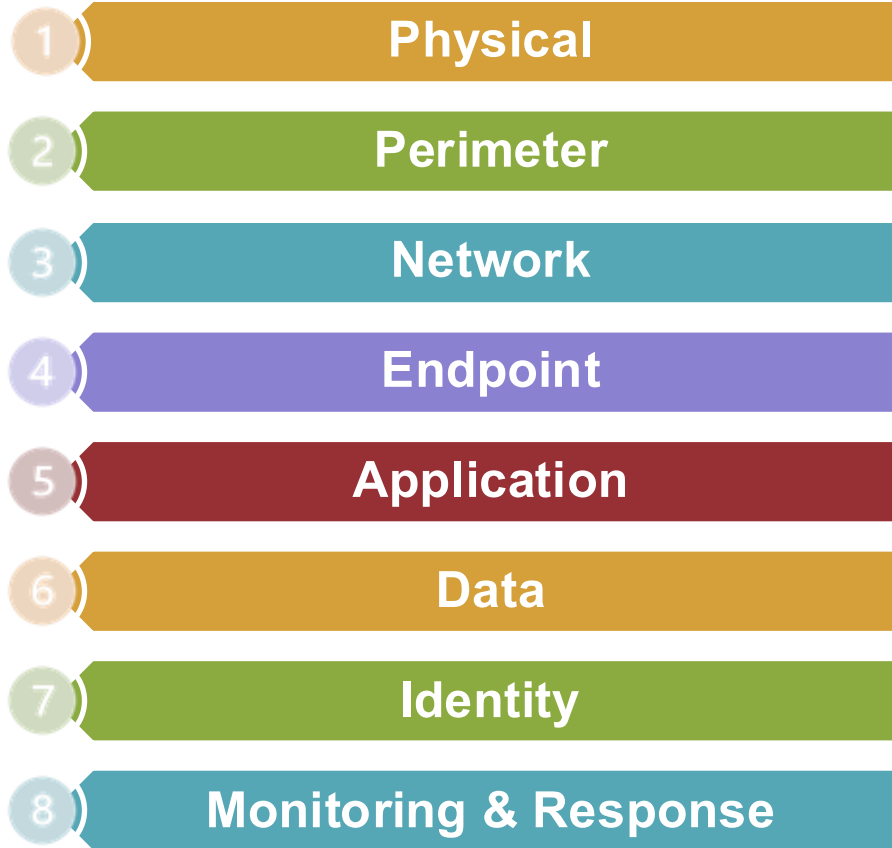


Defense in Depth

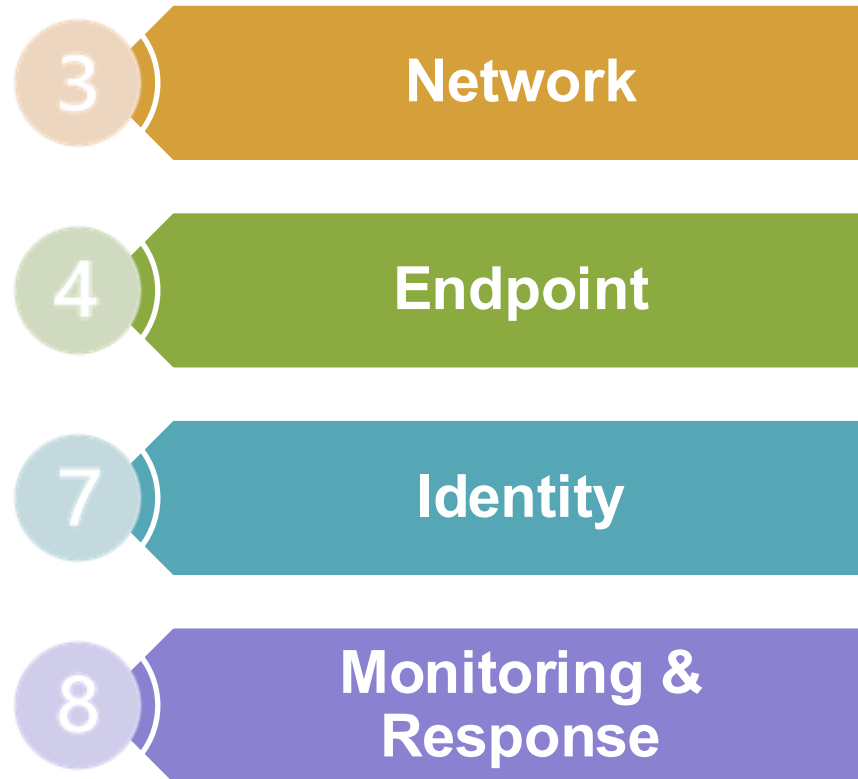
Security is not one tool, it is multiple layers working together

- Layers of various security controls to protect assets & organization
 - Cross-boundary
 - If one layer fails to detect or stop threat, other controls can protect
- Multiple types of controls in different layers
 - Non-technical
 - Physical security
 - Network & host security
 - Application & data security

Defense in Depth Core Layers

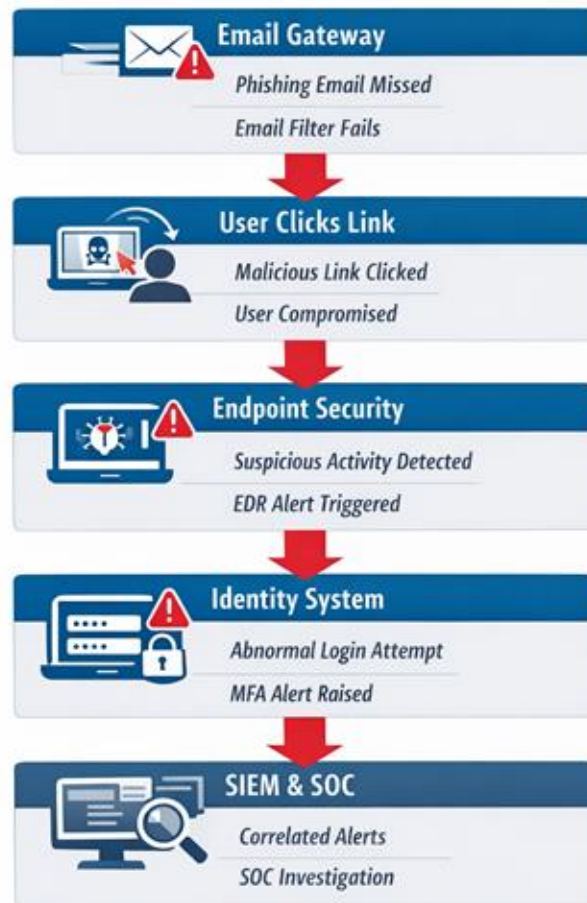


Where SOC Analysts Interact



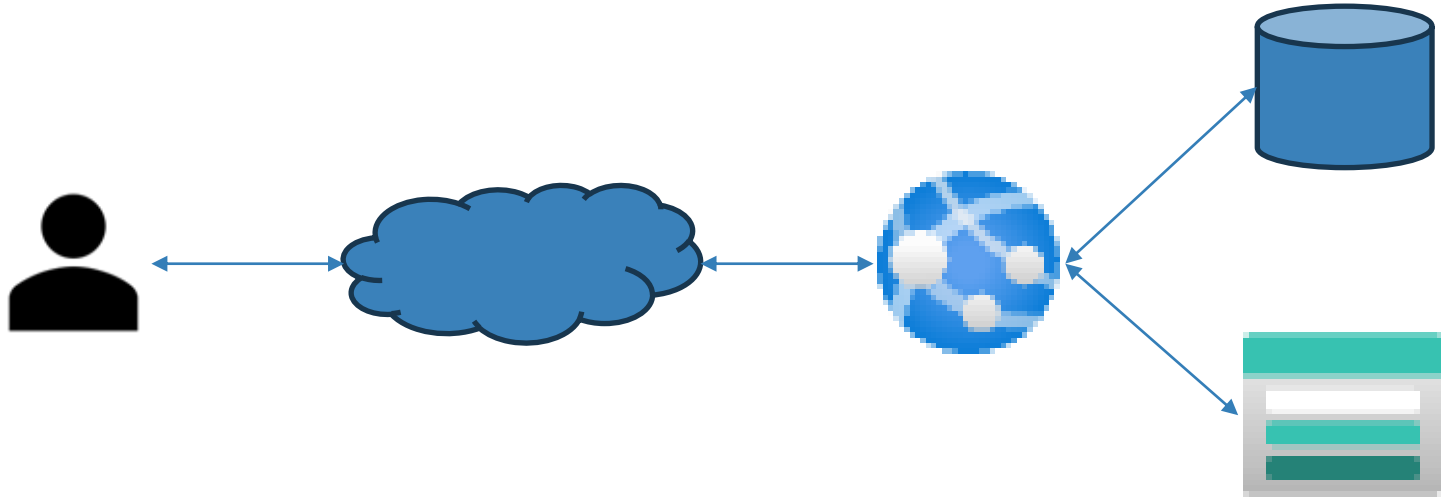
Example: Phishing Attack

Phishing Attack Through the Layers

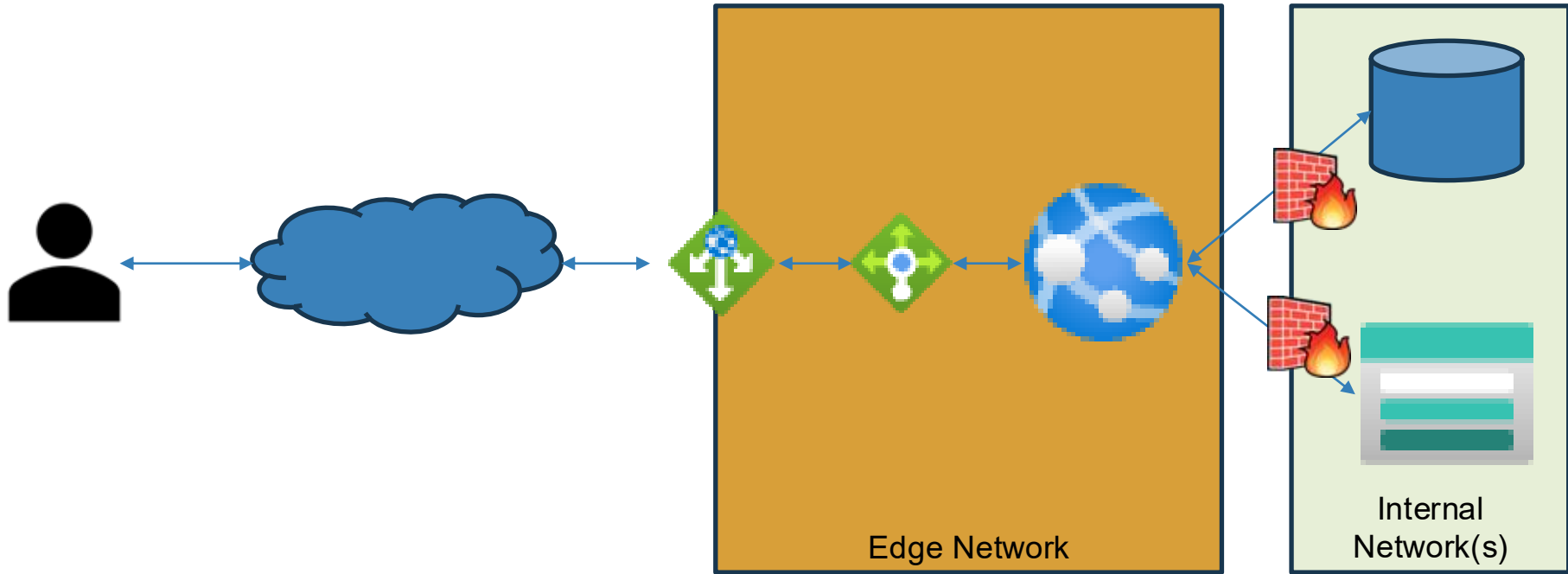


Layered Defense Catches the Attack Progression

Defense in Depth Example



Defense in Depth Example



Limited Access

- Least privilege
 - Only grant the minimum access needed to perform job role
 - Applies to **ALL** users
 - Can apply to application requirements
 - Minimum access to function (no root/admin access)
- Separation of duties
 - One individual should not perform all critical (or privileged) duties
 - Duties must be separated/divided between multiple individuals
 - Can prevent on malicious insider from causing severe damage to org
 - Ex: auditors should not have access to modify

Why This Matter to a SOC Analyst

- + Attacks bypass individual controls
- + Each layer creates **detection opportunities**
- + Alerts from different layers provide **context**
- + Failures at one layer should be caught by another
- + Limited Access secures the environment and impacts the SOC analyst's role

Defense in Depth



Common Threats and Attacks



Why This Matters

- + SOC analysts must quickly recognize malicious activity
- + Understanding threats and attacks improves investigation accuracy
- + Foundation for alert triage and incident response

Threats and Attacks

+ Threat

- + Potential cause of harm
- + Exploits a vulnerability
- + Represents *possibility*

+ Attack

- + Deliberate action by an adversary
- + Aimed at compromising systems or data
- + Represents *execution*

+ Threat vs. Attack

- + Threat = *what could go wrong*
- + Attack = *what is happening or has happened*
- + SOC analysts detect, analyze, and respond to *attacks* arising from *threats*

Malware Threats

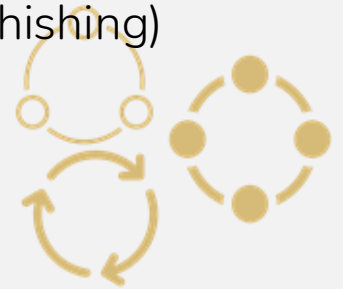
- + Malicious software designed to harm or gain access
- + **Examples:**
 - + Ransomware
 - + Trojans
 - + Worms



Social Engineering Threats



- + Manipulating users to take unsafe actions
- + Examples:
 - + Phishing
 - + Vishing (voice phishing)
 - + Pretexting



Insider Threats

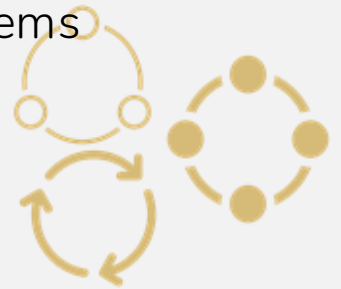
- + Actions by employees/contractors
- + Examples:
 - + Data theft by disgruntled employees
 - + Mishandling sensitive information



Misconfigurations & Poor Security Hygiene



- + Weak or exposed systems increase risk
- + Examples:
 - + Publicly exposed cloud storage
 - + Unpatched systems
 - + Weak or reused passwords



Supply Chain Threats

- + Compromise through third-party software or services
- + **Examples:**
 - + Malicious updates
 - + Dependency poisoning



Threat Actors



Nation-state



Unskilled
attackers



Hacktivists



Organized
crime

Social Engineering Attacks



Credential Attacks

Log Excerpt

Timestamp: 2025-01-14 02:15:12.648Z

Event Category: Authentication

Outcome: Failure

Source IP: 185.231.74.22

Target Account: r.williams

Host: auth-server01

Details: Failed password attempt for user *r.williams*

Timestamp: 2025-01-14 02:15:13.214Z

Event Category: Authentication

Outcome: Failure

Source IP: 185.231.74.22

Target Account: d.lee

Host: auth-server01

Details: Failed password attempt for user *d.lee*

Timestamp: 2025-01-14 02:15:14.901Z

Event Category: Authentication

Outcome: Success

Source IP: 185.231.74.22

Target Account: m.brown

Host: auth-server01

Details: Successful login for user *m.brown*

SIEM Alert

Alert Timestamp: 2025-01-14 02:15:20.000Z

Alert Type: Authentication / Password Spraying

Severity: High

Rule Name: Password Spraying Detected Against Multiple Users

Host: auth-server01

Source IP Address: 185.231.74.22

Reason:

Multiple failed authentication attempts targeting different user accounts from a single external IP address within a short time window. Activity culminated in a successful login for user *m.brown*, indicating a likely password spraying attack.

Summary:

A high-severity authentication alert was generated after 11 failed login attempts were observed from *185.231.74.22*, each targeting a different user account. Within seconds, the same IP achieved a successful login into account *m.brown*. This behavior strongly aligns with known password spraying techniques.

Impact:

Potential compromise of user account *m.brown*
Attacker may attempt lateral movement or data access

Recommended Actions:

Immediately disable or lock the *m.brown* account
Investigate activity following the successful login
Review MFA logs and enforce MFA if not enabled
Block or further inspect traffic from 185.231.74.22
Notify the incident response team if malicious intent is confirmed

Malware Delivery & Execution

Log Excerpt

Timestamp: 2024-06-04 09:47:11.726Z

Event Category: Process

Event Type: Start

Host: workstation01

User: alice

Process Started: C:\Users\alice\AppData\Temp\malicious.exe

Parent Process ID: 4567

Process ID: 6789

Details: Process malicious.exe launched by user *alice*

Timestamp: 2024-06-04 09:47:11.998Z

Event Category: File

Event Type: Creation

Host: workstation01

User: alice

File Created: C:\Users\alice\AppData\Roaming\malware.dll

Details: Suspicious DLL creation detected

Timestamp: 2024-06-04 09:47:12.035Z

Event Category: Network

Event Type: Connection

Host: workstation01

Destination IP: 91.214.67.198

Destination Port: 8080

Protocol: TCP

Details: Outbound connection to suspicious IP address

SIEM Alert

Alert Timestamp: 2024-06-04 09:47:20.000Z

Alert Type: Process / Malware Execution

Severity: Medium

Rule Triggered: *Malware Execution Detected*

Host: workstation01

User: alice

Reason:

Suspicious process execution observed followed by creation of a DLL file and an outbound network connection to a known suspicious IP address.

Summary:

A potentially malicious executable (malicious.exe) was launched on *workstation01* by user *alice*. Immediately following execution, the system created a suspicious DLL file (malware.dll) and attempted an outbound TCP connection to 91.214.67.198:8080, indicating possible malware behavior or command-and-control activity.

Recommended Action:

Isolate the host

Collect memory and disk artifacts

Run full malware scan and EDR triage

Investigate user activity and authentication logs

Vulnerability Exploitation

CVE-2025-8264

PUBLISHED

[View JSON](#) | [User Guide](#)

[Collapse all](#)

Required CVE Record Information

CNA: Snyk

Published: 2025-07-29 Updated: 2025-07-29

Description

Versions of the package z-push/z-push-dev before 2.7.6 are vulnerable to SQL Injection due to unparameterized queries in the IMAP backend. An attacker can inject malicious commands by manipulating the username field in basic authentication. This allows the attacker to access and potentially modify or delete sensitive data from a linked third-party database. **Note:** This vulnerability affects Z-Push installations that utilize the IMAP backend and have the IMAP_FROM_SQL_QUERY option configured. Mitigation Change configuration to use the default or LDAP in backend/imap/config.php php define('IMAP_DEFAULTFROM', ''); or php define('IMAP_DEFAULTFROM', 'ldap');

CVSS 2 Total

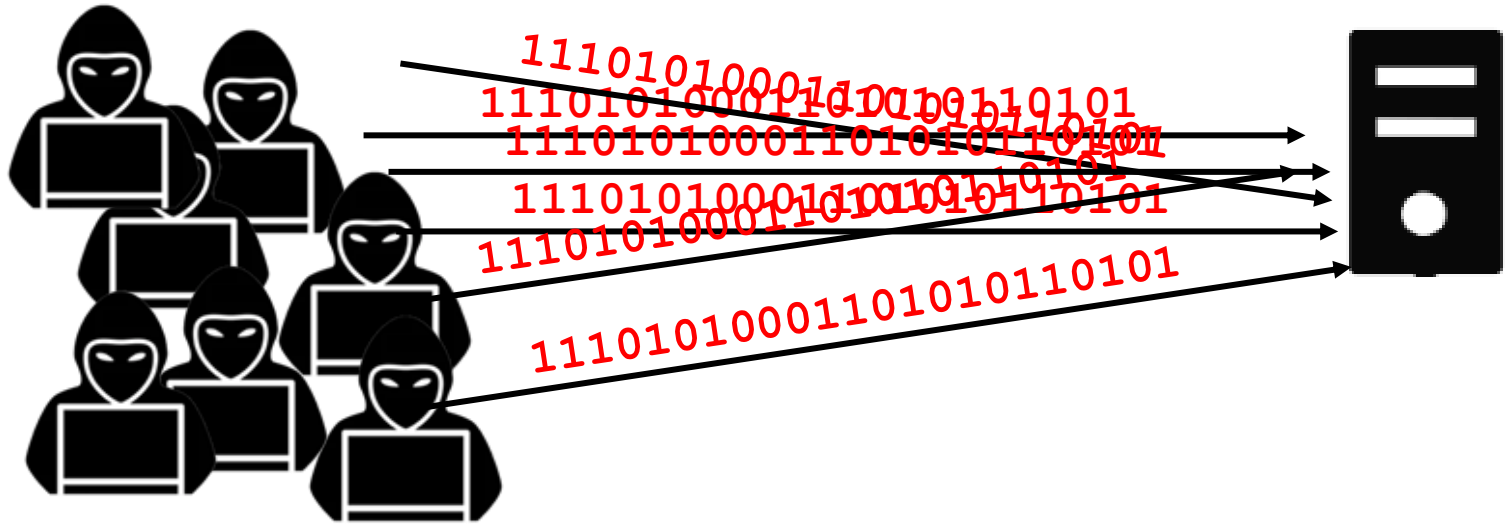
[Learn more](#)

Score	Severity	Version	Vector String
9.0	CRITICAL	3.1	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/H:I/H/A:H/E:P
9.1	CRITICAL	4.0	CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:H/VA:N/SC:H/SI:H/SA:H/E:P



Denial of Service (DoS)

- Denial of service (DoS) - attack designed to disrupt systems
 - Consuming available bandwidth, system resources, etc



Why SOC Analysts Need This Knowledge

- + Identify patterns during alert triage
- + Prioritize high-risk events
- + Understand attacker behavior across the kill chain
- + Improve incident response recommendations

Common Threats and Attacks



Risk Concepts



What Is Risk?

- + Risk = The potential for loss or harm when a threat exploits a vulnerability.

Threat

- Anything capable of causing harm (malware, attacker, insider, natural disaster)

Vulnerability

- Weakness that could be exploited (unpatched system, misconfigurations)

Asset

- Anything of value that must be protected (data, systems, people)

Impact

- The result of an event (data loss, service outage, financial damage)

Likelihood

- How probable an event is

- + SOC relevance: Analysts identify events where threats interact with vulnerabilities.

SOC Analysts and Risk

- + Why Risk Matters for SOC Analysts
 - + Every alert represents *potential* or *actual* risk
 - + SOC decisions affect how the organization detects, classifies, and mitigates risk
 - + Understanding risk improves triage accuracy and helps prioritize incidents
- + SOC Analysts must:
 - + Identify risky behaviors (suspicious logins, malware indicators)
 - + Recognize high-risk patterns (admin compromise, lateral movement)
 - + Prioritize alerts based on potential impact
 - + Escalate incidents that pose unacceptable risk

Risk Concepts



Security Controls



Security Controls

A security control is a safeguard or countermeasure designed to reduce risk by preventing, detecting, or responding to security threats and vulnerabilities.

Control Categories

Technical

Managerial

Operational

Physical

Control Types

Preventive

Deterrent

Detective

Corrective

Compensating

Directive

Technical Controls

- Control implemented as some type of system
 - Hardware, software, firmware, etc
- Examples
 - Network firewall
 - Anti-virus (AV) or Endpoint detection & response (EDR) software
 - Operating system security settings
 - Encryption software
 - Intrusion prevention system (IPS)
 - Access control lists (ACL)

Operational Controls

- Control implemented primarily by person instead of system
- With *managerial controls*, can collectively be referred to as **Administrative Controls**
- Important distinction:
 - All controls are implemented by people, does not define them as operational
- Examples
 - Security guards
 - Training programs
 - IT and security staff
 - Security awareness training for users

Managerial Controls

- Controls that provide oversight and management of security programs
- Frequently describe requirements for other categories of controls
- Examples
 - Risk assessment and management programs
 - Tools used to help identify risk
 - Systems to evaluate and select other security controls
 - Security policies
 - Acceptable Use Policies (AUP) for users
 - Policies state requirements for operational and technical controls

Physical Controls

- Controls that provide security to defined structures or areas
- Used to control and monitor access to various locations
- Examples
 - Security alarms
 - Locked doors
 - Closed-circuit surveillance cameras
 - Security lighting
 - Security ID badges
 - Biometric security locks

Control Types

- Preventive
 - Eliminate or reduce likelihood of successful attack
 - Operates before attack can take place
 - ACLs, AV/EDR
- Deterrent
 - Designed to discourage attacker from attempting attack
 - May not prevent any type of access
 - “No trespassing” signs, legal disclaimers in systems
- Detective
 - Identifies and records (logs) attempted (or successful) attacks/intrusions
 - Like deterrent, not designed to prevent attack
 - Logging systems

Control Types

- Corrective
 - Assists in reducing or eliminating the effect/impact of attack
 - Used after attack has concluded
 - Backup data/systems, patching exploited vulnerability
- Compensating
 - Secondary (or substitute) control to primary control
 - Provides same or better level of protection
 - Uses different technology or methodology (defense in depth)
- Directive
 - Implemented to monitor regulatory compliance
 - Provide guidance aligned specifically with organizational requirements

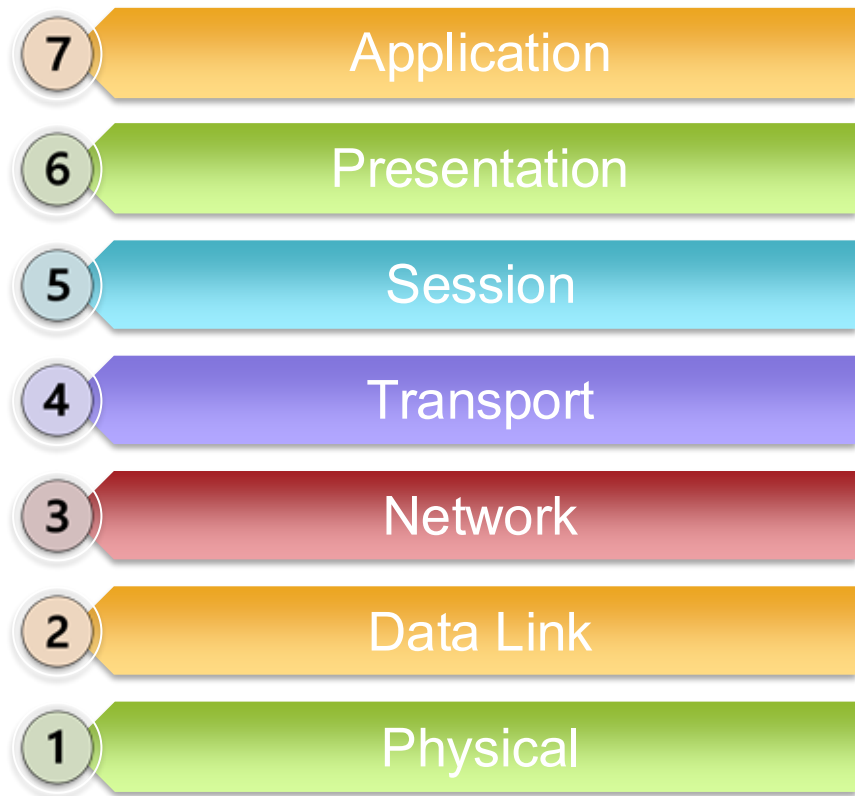
Security Controls



Network Models (OSI and TCP/IP)



The OSI Model

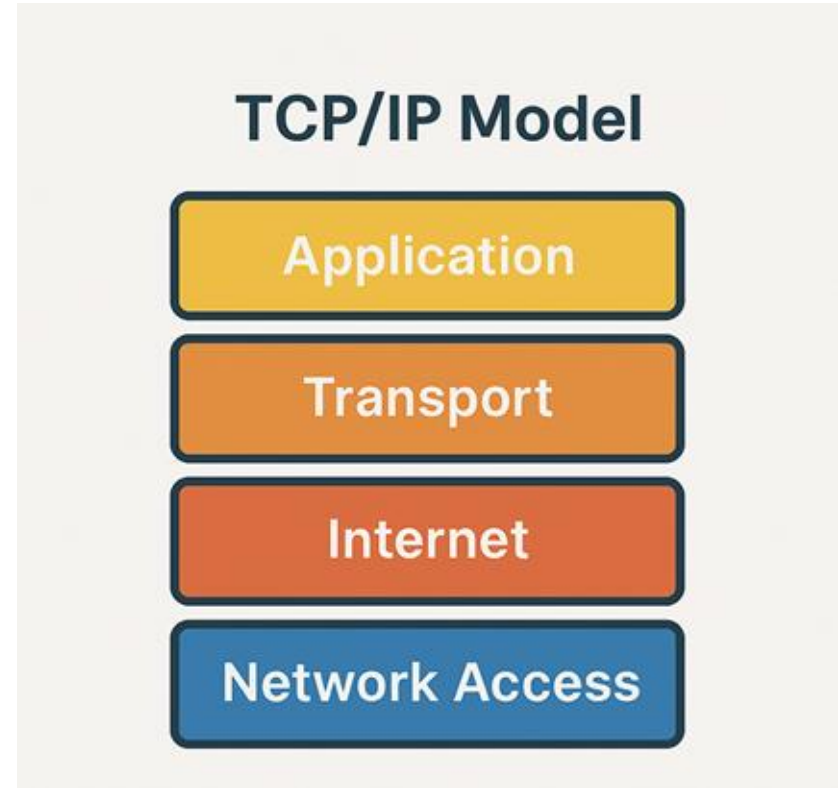


The OSI Model

#	OSI LAYER	FUNCTION	EXAMPLES
7	APPLICATION	Provides network services directly to end-users or applications.	HTTP, FTP, IRC,, DNS, SMTP
6	PRESENTATION	Translates data between the application layer and lower layers. Responsible for data format translation, encryption, and compression to ensure that data is presented in a readable format.	SSL/TLS, MIME, JPEG/GIF, ASCII/UTF-8
5	SESSION	Manages sessions or connections between applications. Handles synchronization, dialog control, and token management. (Interhost communication)	NetBIOS, RPC, SMB
4	TRANSPORT	Ensures end-to-end communication and provides flow control.	TCP, UDP
3	NETWORK	Responsible for logical addressing and routing.(Logical Addressing)	IP, ICMP, IPSec
2	DATA LINK	Manages access to the physical medium and provides error detection. Responsible for framing, addressing, and error checking of data frames. (Physical addressing)	Ethernet, PPP, Switches etc
1	PHYSICAL	Deals with the physical connection between devices.	USB, Ethernet Cables, Coax, Fiber, Hubs etc

The TCP/IP Model

- + 1. Application Layer
 - + Where user-facing apps and protocols operate
 - + Examples: HTTP/HTTPS, DNS, SMTP, FTP
- + 2. Transport Layer
 - + End-to-end communication between devices
 - + Protocols: **TCP** (reliable), **UDP** (fast, connectionless)
- + 3. Internet Layer
 - + Moves packets across networks using **IP addressing**
 - + Protocols: IPv4, IPv6, ICMP
- + 4. Network Access Layer
 - + Physical + data link transmission
 - + Examples: Ethernet, Wi-Fi, MAC addresses



Why It Matters to a SOC Analyst

- **Faster, More Accurate Alert Triage**

Understanding OSI layers helps analysts quickly identify where an issue exists, reducing time spent investigating the wrong part of the network or application stack.

- **Clearer Communication and Escalation**

Using OSI-aligned terminology allows SOC analysts to communicate findings clearly to Tier 2, incident response, and network teams.

- **Efficient Use of Logs and Tools**

Knowing which OSI layer is involved helps analysts go directly to the most relevant logs and monitoring tools.

- **Accurate Incident Classification and Ticketing**

OSI awareness supports correct incident categorization, severity assignment, and routing within SOC workflows.

- **Stronger Threat Detection Context**

Mapping activity to OSI layers helps analysts understand attacker behavior and recognize where an attack fits in the kill chain.

- **Reduced False Positives and Unnecessary Escalations**

Analysts can better distinguish normal protocol behavior from suspicious activity, improving SOC efficiency and confidence in alerts.



Demo

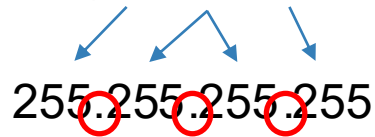
Fundamentals of IP Addressing



Introduction to IPv4

- + 32-bit addressing system
- + Logical address for a network defined by IANA
- + IPv4 addresses are comprised of 4 octets
- + Dotted decimal notation is used to segment the octet

Octets (8-bit numbers 0-255)



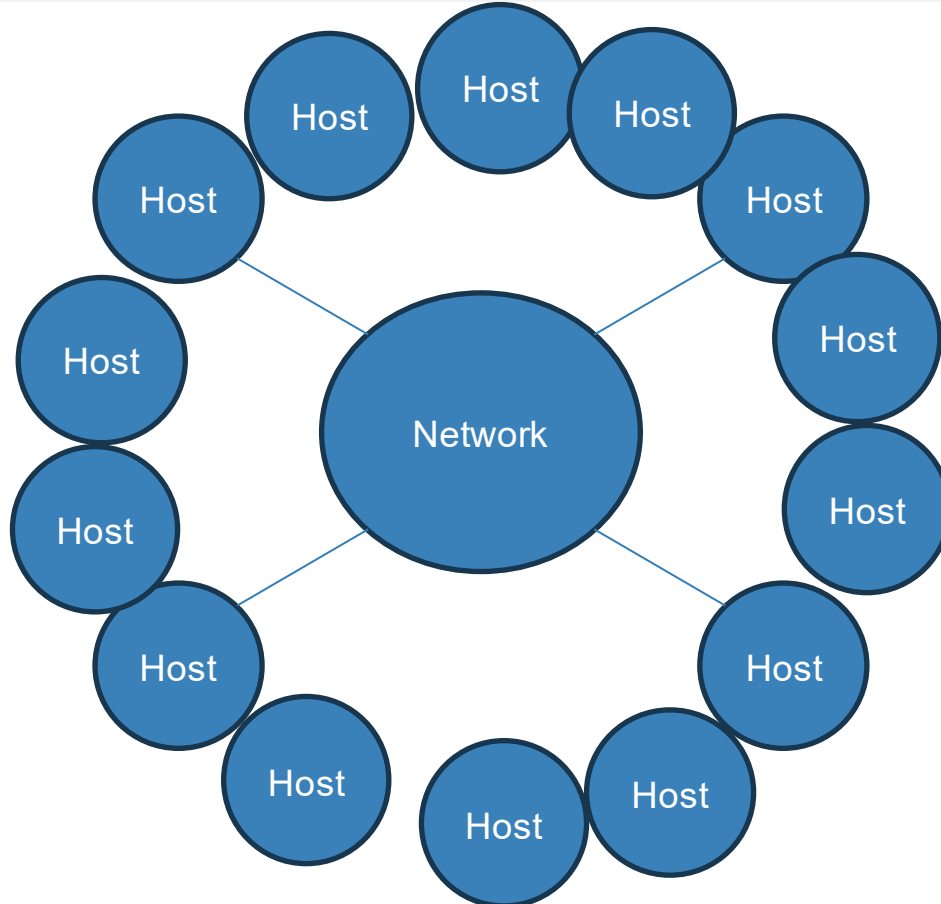
255.255.255.255

192.168.1.10 → 11000000.10101000.00000001.00001010

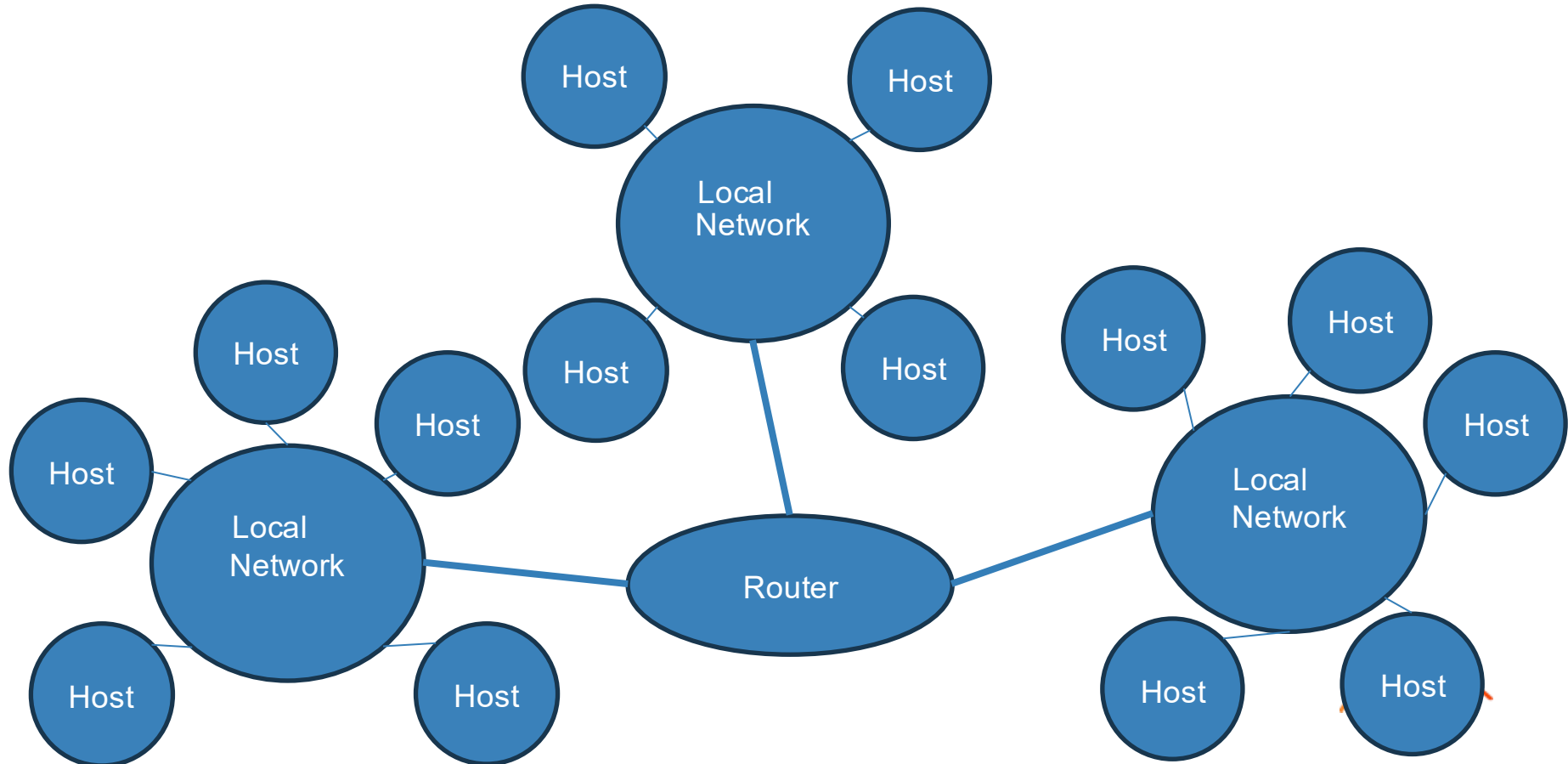
Interpretation of IP Addresses

- IP addresses identify two things about you;
 - The local network you are on
 - A unique host identifier for your NIC on that network
- IP addresses can be static or dynamic
 - Static addresses for devices that never move
 - Dynamic addresses for mobile devices and laptops
- IP addresses sometimes called a “logical address”

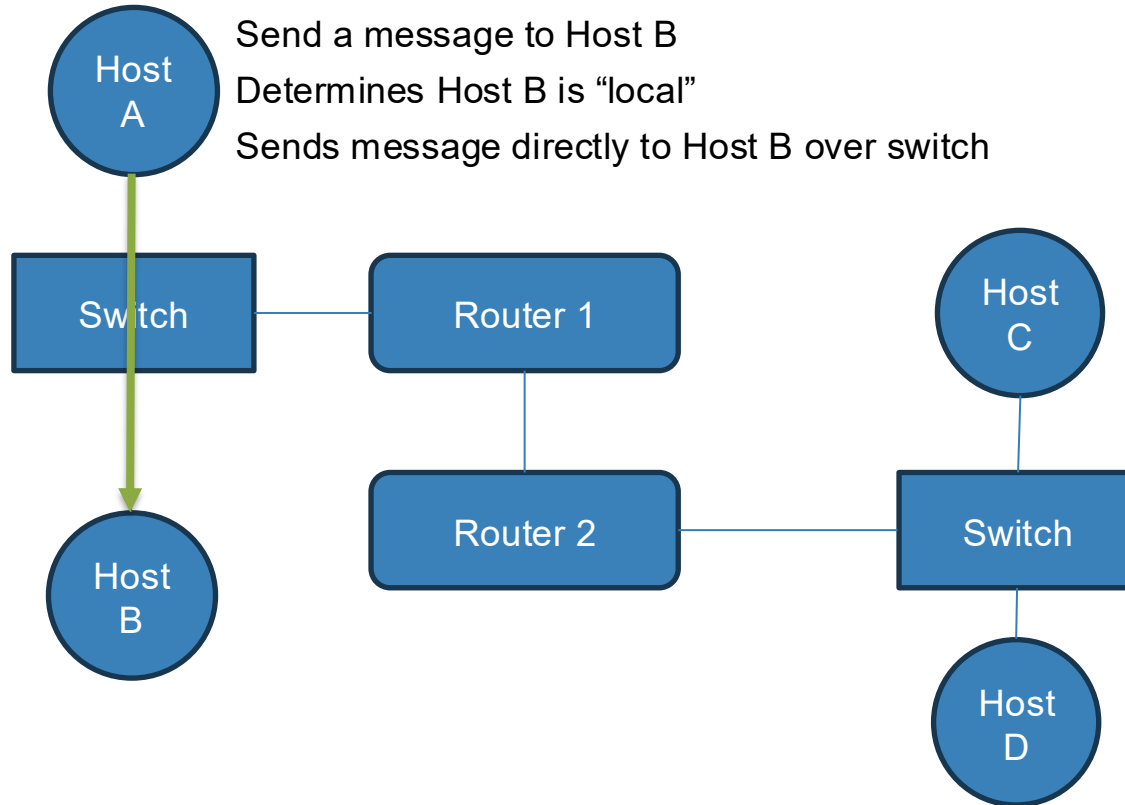
A Word on “Local” Network



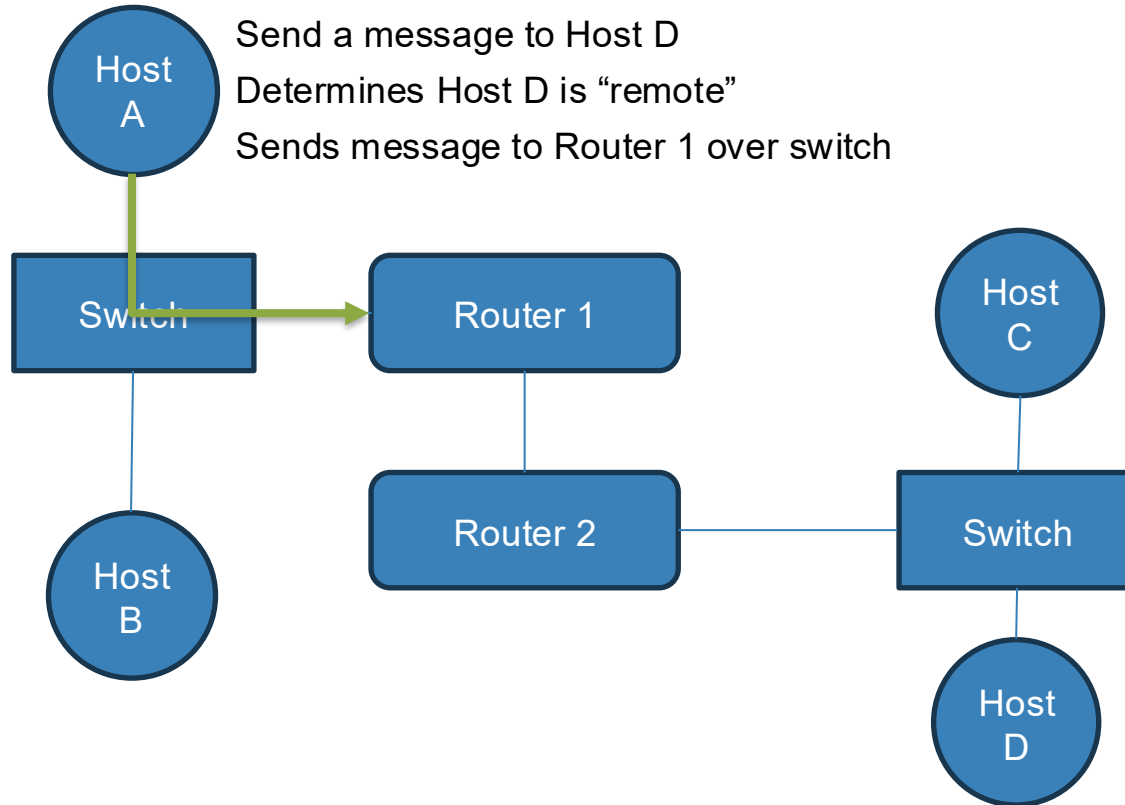
A Word on “Local” Network



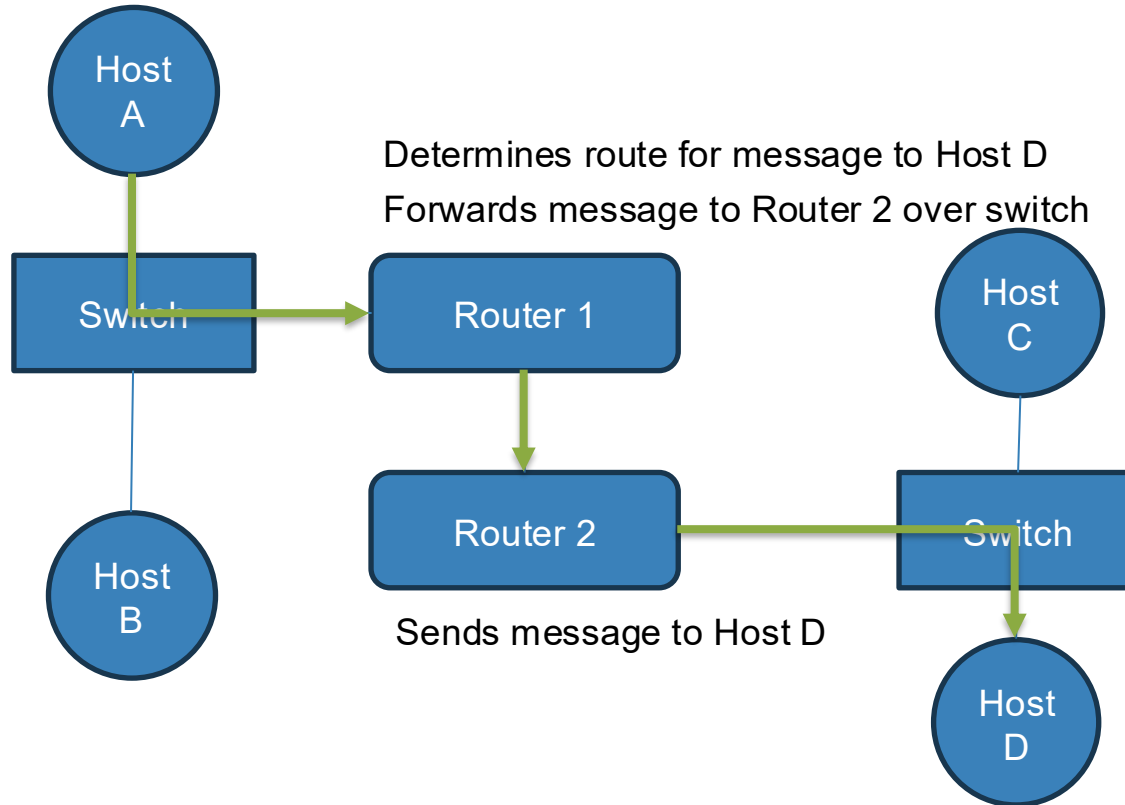
What “Local” Actually means



What “Local” Actually means



What “Local” Actually means



Why IP Addressing Matters to a SOC Analyst

- + Common indicator of attack
 - + unusual IP destinations
 - + Unusual traffic from an IP address
 - + Known dangerous IP addresses
- + IP Address is part of (most) every packet that you will analyze
 - + First identification of a host
 - + Identifies endpoints as local or remote

Fundamentals of IP Addressing



IPv4 Addressing



IPv4 Addresses: Public & Private

- + IP addresses “leased” to a corporation are known as *public IP addresses*.
- + IP addresses that are unregistered and may overlap from one company to the next, are known as *private IP addresses*.

IPv4 Addresses: Private

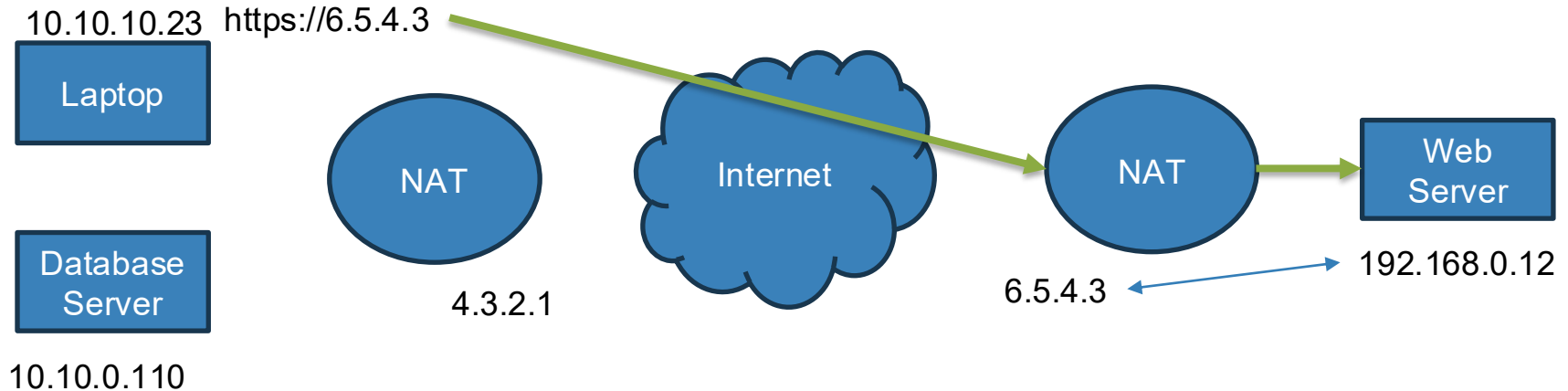
- + Private IPv4 address:
 - + Defined in RFC 1918
 - + For internal use only
- + Range of private address
 - + Class A : 10.0.0.0 through 10.255.255.255
 - + Class B : 172.16.0.0 through 172.31.255.255
 - + Class C : 192.168.0.0 through 192.168.255.255

IPv4 Addresses: Public

- + Public IPv4 addresses
 - + Globally unique
 - + Should be purchased
 - + Usually used in Internet edge
- + Range of public addresses
 - + Beyond the RFC 1918 space, all addresses are public

Network Address Translation

- + There are approximately 4.3 billion public IPv4 addresses
- + There are 10s of billions of devices connected to the internet



Classless Inter-Domain Routing

- + By the early 1980's classful IP addressing was no longer scalable
- + CIDR (Classless Inter-Domain Routing) was invented
 - + IP was changed such that the boundary between network and host bits could be anywhere within the 32-bit IP address
 - + Boundary identified by an additional value paired with an IP address called a "subnet mask"
 - + Subnet mask written as "slash" notation
 - + 10.10.10.1 /22

Purpose & Construction Of Masks

- Subnet masks are required to identify the network portion of an address
- Subnet Masks are 32-bits in length, represented in dotted-decimal notation or “slash” notation.
- Each bit of a subnet mask is compared against corresponding bit-position in IPv4 address
 - A “1-bit” in mask indicates corresponding bit in IPv4 address is part of the network portion.
 - A “0-bit” in mask indicates corresponding bit in IPv4 address is part of the host portion.

Important Values To Remember

Binary Value	Decimal Value
00000000	0
10000000	128
11000000	192
11100000	224
11110000	240
11111000	248
11111100	252
11111110	254
11111111	255

CIDR Examples

- + Simple Example
 - + 10.10.0.0/16 (Mask=255.255.0.0)
 - + IP address=10.10.0.6

00001010	00001010	00000000	00000110
11111111	11111111	00000000	00000000
00001010	00001010	00000000	00000000

Network = 10.10.0.0

CIDR Examples

- + More Interesting Example
 - + 10.10.192.0/18 (Mask=255.255.192.0)
 - + IP address=10.10.194.6

00001010	00001010	11000010	00000110
11111111	11111111	11000000	00000000
00001010	00001010	11000000	00000000

Network = 10.10.192.0

Demo

IPv4 Addressing



IPv6 Addressing



Introduction to IPv6

- + Late 1980s, researchers realized that at some point in the future, IPv4 addresses and subnets would be exhausted.
- + IPv6 created: an update (1998) to the Internet Protocol (IPv4)
- + Includes:
 - + Modifications made to the IP header
 - + Addressing structure
 - + Protocol operations
 - + 128-bit addressing system
- + IPv6 provides an **astronomically large address space** — enough to assign **billions of IP addresses to every person on Earth** and still not run out.

IPv6 Addressing Structure

- + Addresses expressed in hexadecimal instead of decimal
 - + Colon “:” used to separate group of four-hex characters (a hexadecimal “word”)
 - + 4 bits = 1 hex character (a “nibble”)

+ Example:

2	0	0	1	:	0	0	B	C	:	0	0	0	0	:	0	0	0	0	:	0	0	0	0	:	0	0	0	1	:	1	2	3	0	:	0	0	0	A
---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---

8 words x 4 nibbles / word x 4 bits / nibble = 128 bits

Abbreviating IPv6 Addresses

- + IPv6 addresses can be abbreviated using some simple rules to minimize overhead
 - + Leading zeros in each word (16-bits) can be omitted
 - + A **single set** of consecutive zeros can be replaced with double colon “**::**”
 - + Multiple double colons are not allowed in a single address
 - + Example: 2001:0000:0000:0033:0000:0001:0000:000A/64
 - + This is okay: 2001::**33**:0:1:0:A/64
 - + This is NOT okay: 2001::**33**::1:0:A/64

Types of IPv6 Addresses

+ Link-local addresses

- + Assigned automatically as an IPv6 host comes online
- + Similar to the 169.254.x.x address of IPv4
- + Always begin with “FE80::/10”
- + Last 64 bits is the 48-bit MAC address with “FFFE” inserted in the middle

+ Global Unicast Addresses

- + Have their high-level 3 bits set to 001; ex: 2000::/3
- + Global routing prefix is 48 bit or less

Types of IPv6 Addresses

Address Type	Prefix	Local or Remote	Routable on Internet
Link-Local	FE80::/10	Local only	✗ No
Unique Local (ULA)	FC00::/7 (FD00::/8)	Internal	✗ No
Global Unicast	2000::/3	Remote	✓ Yes

Demo

IPv6 Addressing



Common Protocols and Port Numbers



What are Port Numbers?

<https://10.10.123/home:443>



80, 443 Web Svr

21 FTP Svr

25 SMTP Svr



10.10.10.123

What are Port Numbers?

<https://10.10.123/home:443>



10.10.0.12



80, 443 Web Svr

21 FTP Svr

25 SMTP Svr



10.10.10.123

What are Port Numbers?

<https://10.10.123/home:443>

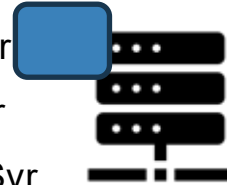


10.10.0.12

80, 443 Web Svr

21 FTP Svr

25 SMTP Svr



10.10.10.123

Common TCP & UDP Application Ports

A TCP or UDP port specifies which upper-layer application should handle the data, such as HTTP for web traffic (TCP Port 80) or DNS for name resolution (UDP Port 53)

Common TCP Application Ports

- FTP: 20/21
- SFTP/SSH: 22
- Telnet: 23
- SMTP: 25
- HTTP: 80
- LDAP: 389
- HTTPS: 443
- SMB: 445
- SMTPS: 587
- LDAPS: 636
- SQL Server: 1433
- RDP: 3389
- SIP: 5061

Common UDP Application Ports

- DNS: 53
- DHCP: 67/68
- TFTP: 69
- NTP: 123
- SNMP: 161/162
- Syslog: 514
- SIP: 5060

Demo

Network Devices and Their Security Roles



Network Devices – Switches & Routers

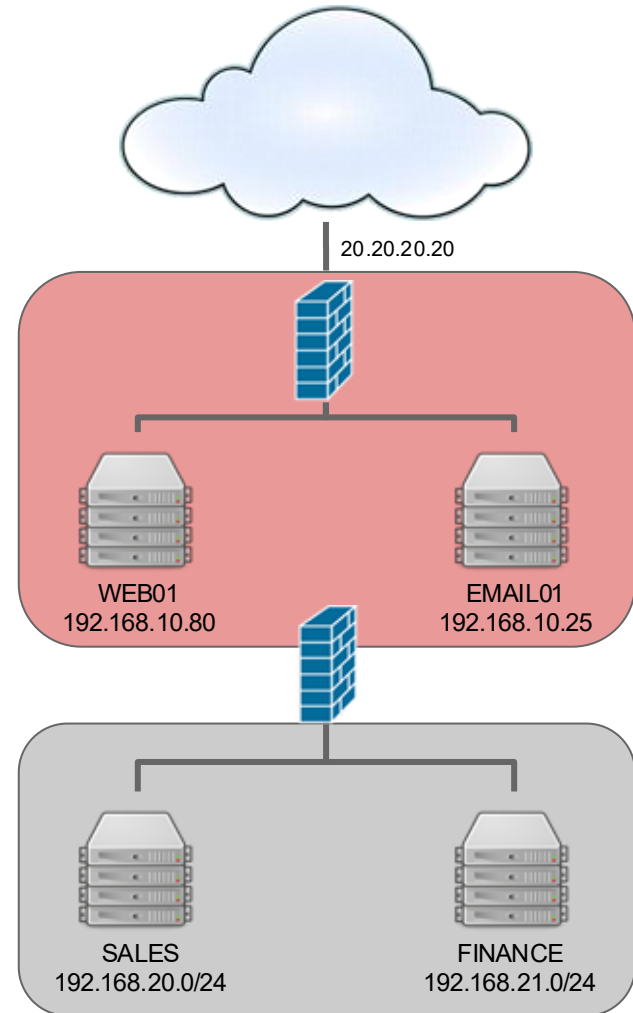
- + Switches – Layer 2
 - + Port Security
 - + VLAN
 - + 802.1x Authentication
 - + Monitored for ARP/MAC table changes



- + Routers
 - + Separate internal and external networks
 - + Enforce simple Access Control Lists (ACLs)
 - + Provide traffic data to logging tools



Network Devices - Firewalls

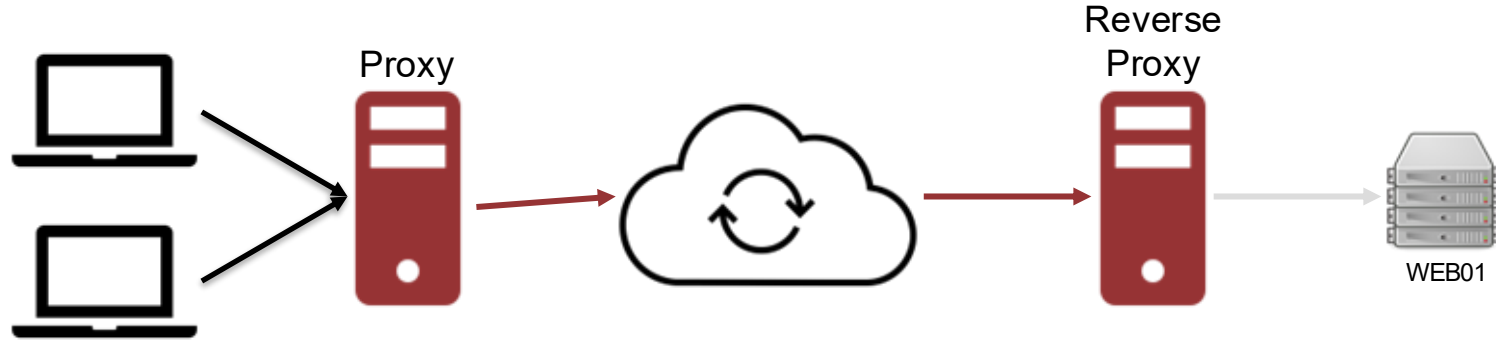


Network Devices – IDS/IPS

Intrusion Detection/Prevention Systems

- + Monitor network traffic for malicious patterns or behaviors
- + **IDS:** Alerts on suspicious activity
- + **IPS:** Blocks malicious traffic inline
- + **Security Role:**
 - + Generate high-value alerts for SOC's
 - + Provide visibility into exploitation attempts
 - + Block suspicious activity (IPS)

Network Devices - Proxy Servers



- + Intermediaries between users and the internet
- + **Security Role:**
 - + Enforce acceptable use policies
 - + Log web traffic for investigation
 - + Filter malware or phishing attempts

Network Devices - Network Monitoring & Logging Devices

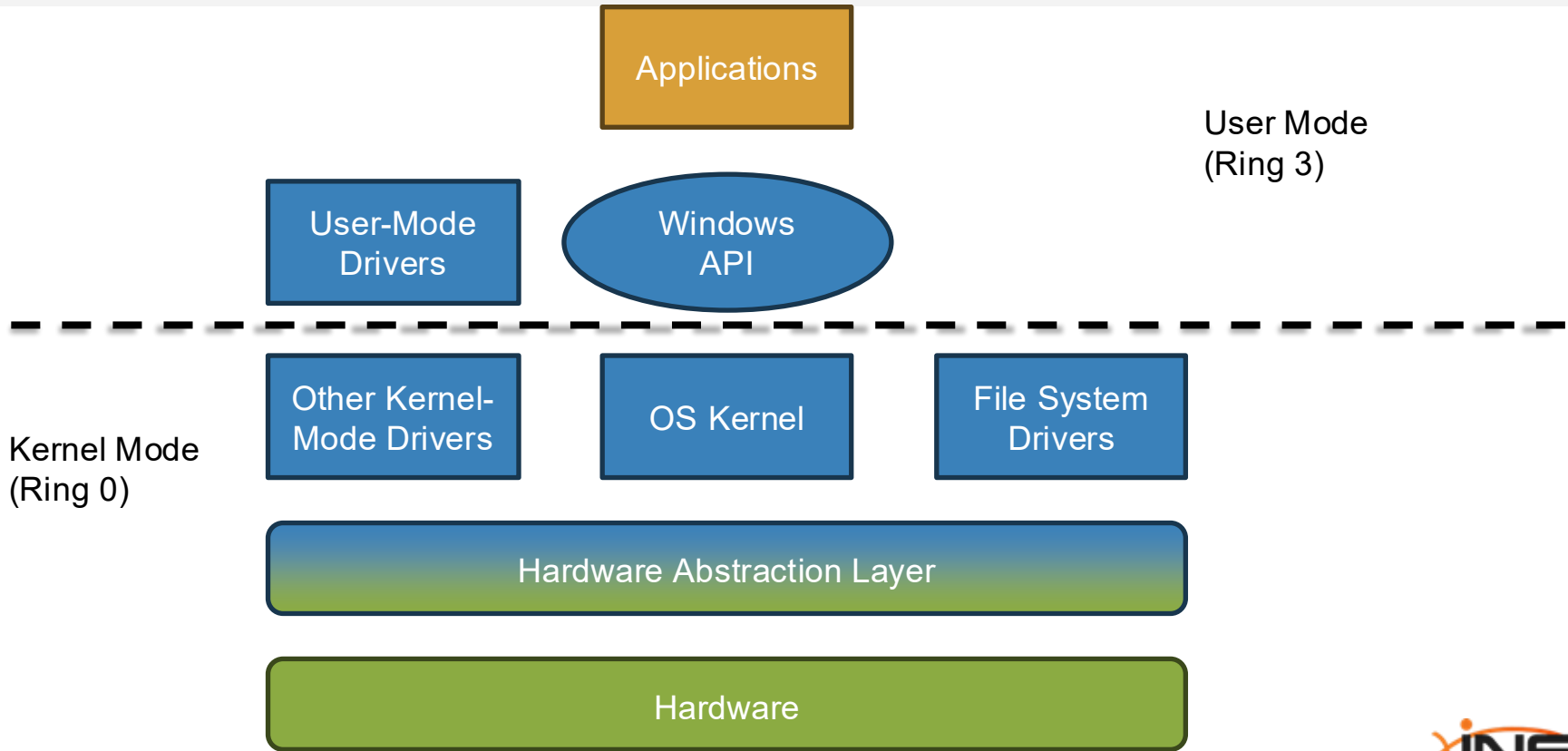
- + Examples:
 - + TAPs – (test access point) dedicated devices added to network
 - + SPAN ports – Built into network switches
 - + Packet brokers/collectors – intermediate between TAP/SPAN and tools
- + **Security Role:**
 - + Provide raw packet capture or flow data
 - + Feed IDS, SIEM, and forensic tools

Demo

Windows Architecture and Components



Windows Subsystems



What Are Windows Services?

Services are background programs that handle system functions (e.g., printing, updates).



Types include automatic (start at boot), manual (on demand), and disabled.



Services run with elevated privileges and are essential for system operations.

User Interfaces: GUI vs CLI



Graphical User Interface (GUI): Uses windows, icons, menus, and a pointer (mouse or touch) for interaction. Example: the Windows desktop environment where you can click icons and buttons to operate the system.



Command-Line Interface (CLI): Text-based interface where users type commands to perform operations. Example: Windows Command Prompt or PowerShell, where you enter commands to manage files or configure settings.



Use Cases: GUI is intuitive for most users and daily tasks (browsing files, settings). CLI offers powerful automation and is preferred for advanced tasks or scripting (system admins use PowerShell to configure systems efficiently).

Desktop, Start Menu, and Taskbar

Desktop: The main screen area after logging in, serving as a workspace for shortcuts, files, and folders. Users often keep frequently used file and program shortcuts here for convenience.



Start Menu: Central menu (opened via the Start button) that lists installed programs and provides a search bar. Use it to launch applications, find documents, or access system settings quickly.



Taskbar: The horizontal bar (usually at the bottom) that shows open app windows as icons. It also contains the Start button on the left and the system tray (notification area with clock, volume, network icons) on the right.

Understanding the Windows Registry



The registry is a hierarchical database that stores system and application settings.

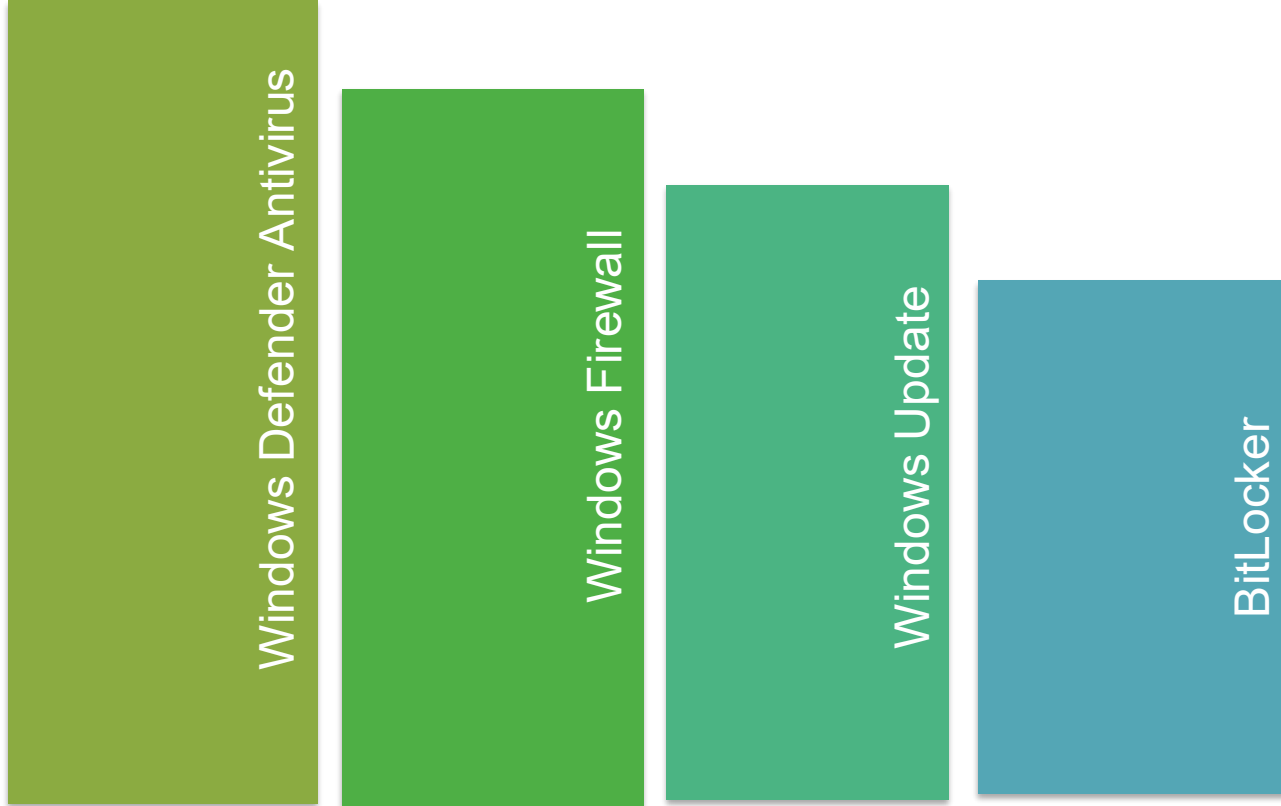


It includes system-wide and user-specific configurations.



Changes to the registry can affect application behavior, startup, drivers, and more.

Windows Security Features



Demo

Key Windows System Locations and Files



Drive Letters and File Paths

Drive Letters:

- Windows assigns a letter to each storage volume or drive (e.g., C:, D:). The main system drive is usually C:. These letters are used to reference different disks or partitions.

File Path Format:

- A path specifies a file's location on a drive. Example:
C:\Users\Ahmed\Documents\Report.docx

Absolute vs Relative Paths:

- An absolute path starts from the root of a drive:
C:\Folder\File.txt
- whereas a relative path is defined from your current directory:
Folder\File.txt

Network Paths:

- Shared network resources use UNC paths
\\ServerName\ShareName\Folder

Core System Executables

File	Path	Purpose
ntoskrnl.exe	C:\Windows\System32\	Windows kernel—manages memory, processes, drivers.
winload.exe	C:\Windows\System32\	Boot loader that loads the kernel.
winresume.exe	C:\Windows\System32\	Resumes Windows from hibernation.
smss.exe	C:\Windows\System32\	Session Manager—first user-mode process created by the kernel.
csrss.exe	C:\Windows\System32\	Client/Server Runtime—handles console and thread creation.
winlogon.exe	C:\Windows\System32\	Manages logon, Ctrl+Alt+Del, security policies.
services.exe	C:\Windows\System32\	System Service Control Manager.
lsass.exe	C:\Windows\System32\	Local Security Authority—authentication, AD integrity. A high-value malware target.



Other Key Files

- + Drivers
 - + C:\Windows\System32\drivers\
Contains .sys files (kernel drivers). Common for rootkits to hide here.
- + System DLLs
 - + C:\Windows\System32\
+ C:\Windows\SysWOW64\ (for 32-bit apps on 64-bit OS)
- + Critical DLLs include:
 - + **kernel32.dll** – Base Windows API (memory, I/O).
 - + **ntdll.dll** – Interface between user mode and kernel.
 - + **advapi32.dll** – Registry, security functions.
 - + **user32.dll** – GUI interactions.
- + Hosts file: C:\Windows\System32\drivers\etc\hosts

Registry Hives

Hive File

Function

SYSTEM

System-wide configuration (drivers, services).

SOFTWARE

Installed programs, settings.

SAM

Local account database & password hashes.

SECURITY

Local security policies.

DEFAULT

Default user profile settings.

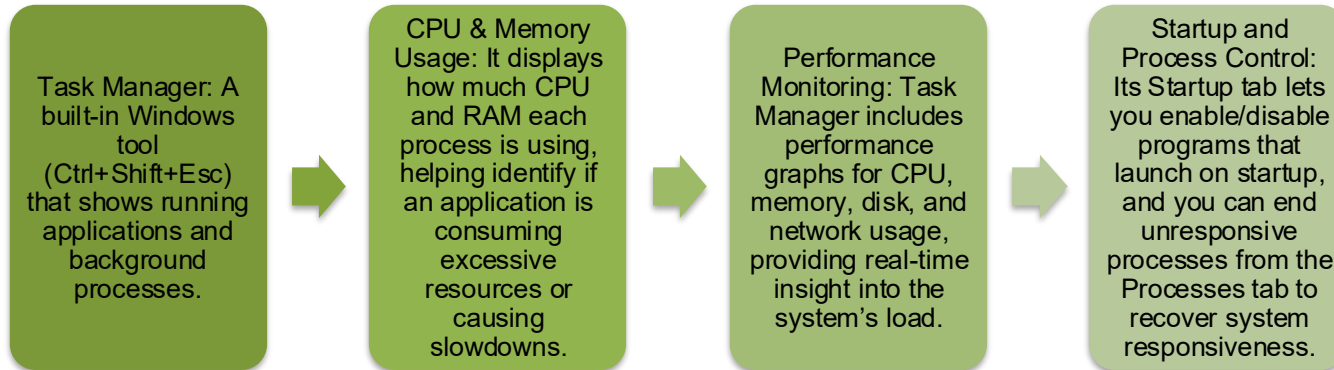


Demo

Fundamental Windows Management Tools



Process Monitoring with Task Manager



System Settings and Control Panel



Settings App:

A modern interface (introduced in Windows 10) that organizes system configuration options in a user-friendly way. It has categories like System, Devices, Network & Internet, Accounts, etc., for common settings.



Control Panel:

The traditional settings interface from older versions of Windows. It's still present for many advanced or legacy settings (e.g., Device Manager, old user account settings) that might not be in the new Settings app.



Typical Tasks:

Both Settings and Control Panel allow you to change display or sound settings, manage devices and printers, uninstall programs, adjust user accounts, and configure security and network settings.



How to Access:

Open Settings from the Start Menu or by pressing Windows + I. Open Control Panel by searching for "Control Panel" in the Start search. You can also jump directly to specific settings (e.g., "Add or remove programs") via search.

Managing Services with services.msc

1

Open the Services console via Run > services.msc.

2

Start, stop, or restart services from the interface.

3

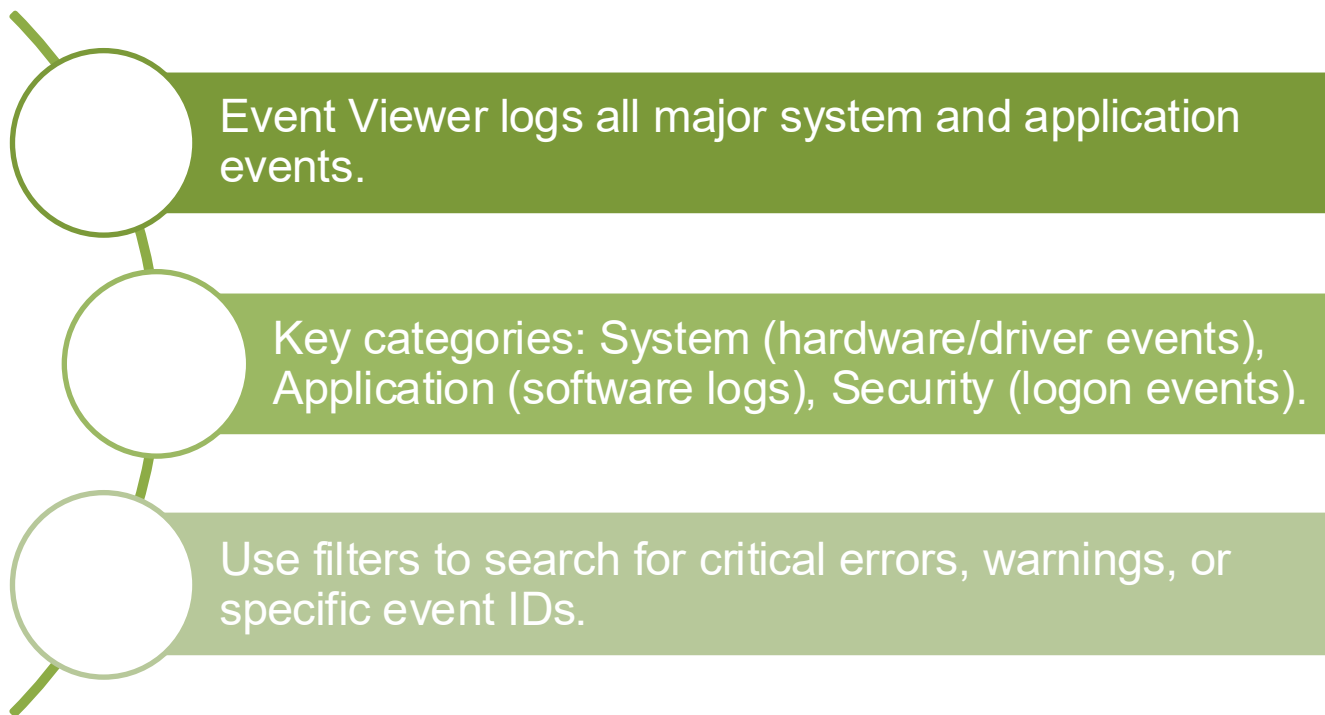
Set services to Automatic (Delayed Start) to improve boot performance.

Demo

Event Viewer and Windows Security Logs



Using Event Viewer



Event Viewer logs all major system and application events.

Key categories: System (hardware/driver events), Application (software logs), Security (logon events).

Use filters to search for critical errors, warnings, or specific event IDs.

Demo

Windows User and Permissions Basics



Windows User Account Types

Administrator:
Has full system access. Administrators can install software, change system settings, and access all files. Because of these privileges, admin accounts should be used only when necessary for system changes.



Standard User:
Has limited access for everyday tasks (browsing, document editing, running most programs). Standard users cannot install certain software or change critical system settings without an administrator's approval (UAC prompt).



Guest: A very limited account type intended for temporary use (guests). Guests cannot install software or change settings and have no personalized storage. (This account is disabled by default on modern Windows for security.)



Least Privilege Practice: For better security, day-to-day work should be done under a standard account. Only use an admin account when performing tasks that require elevated rights, to reduce risk of unwanted system changes.

Managing User Accounts

Creating Accounts:

Go to Settings > Accounts > Family & other users (or use Control Panel's User Accounts) to add a new user. You can create a local account or use a Microsoft account login, and choose whether it's Standard or Administrator.



Deleting Accounts:

Admins can remove a user account via the same menu. When deleting, Windows offers to either delete the user's files or keep them in the user's directory for retrieval. Always back up important data before removing accounts.



Changing Account Type:

In the Accounts settings, an admin can change a user's account type (Standard or Administrator). This elevates or restricts the user's permissions. It's a way to grant a user admin rights or strip them if no longer needed.



User Profiles:

Each account has a profile folder (under C:\Users\<username>) containing that user's Desktop, Documents, and other data. Deleting an account can also remove this profile folder (if chosen), freeing up space but erasing the user's files.

Password Policies and Account Security

Strong Passwords:

- Use passwords that are hard to guess (at least 8+ characters, mixing letters, numbers, symbols). Avoid common words or personal info. Strong passwords protect accounts from being easily compromised.

Password Expiration:

- Organizations may enforce regular password changes (e.g., every 90 days). Windows allows setting expiration on local accounts via security policy. Regular updates of passwords limit the time a stolen password is valid.

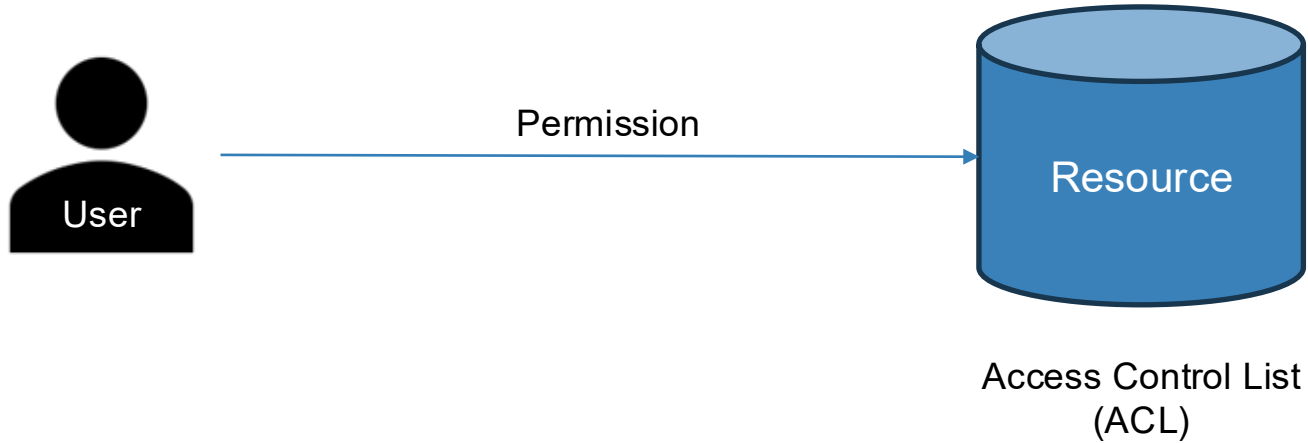
Account Lockout:

- Windows can lock an account after a number of failed login attempts (configurable in local security policy). This lockout (for a duration or until an admin unlocks) helps thwart brute-force password guessing attacks.

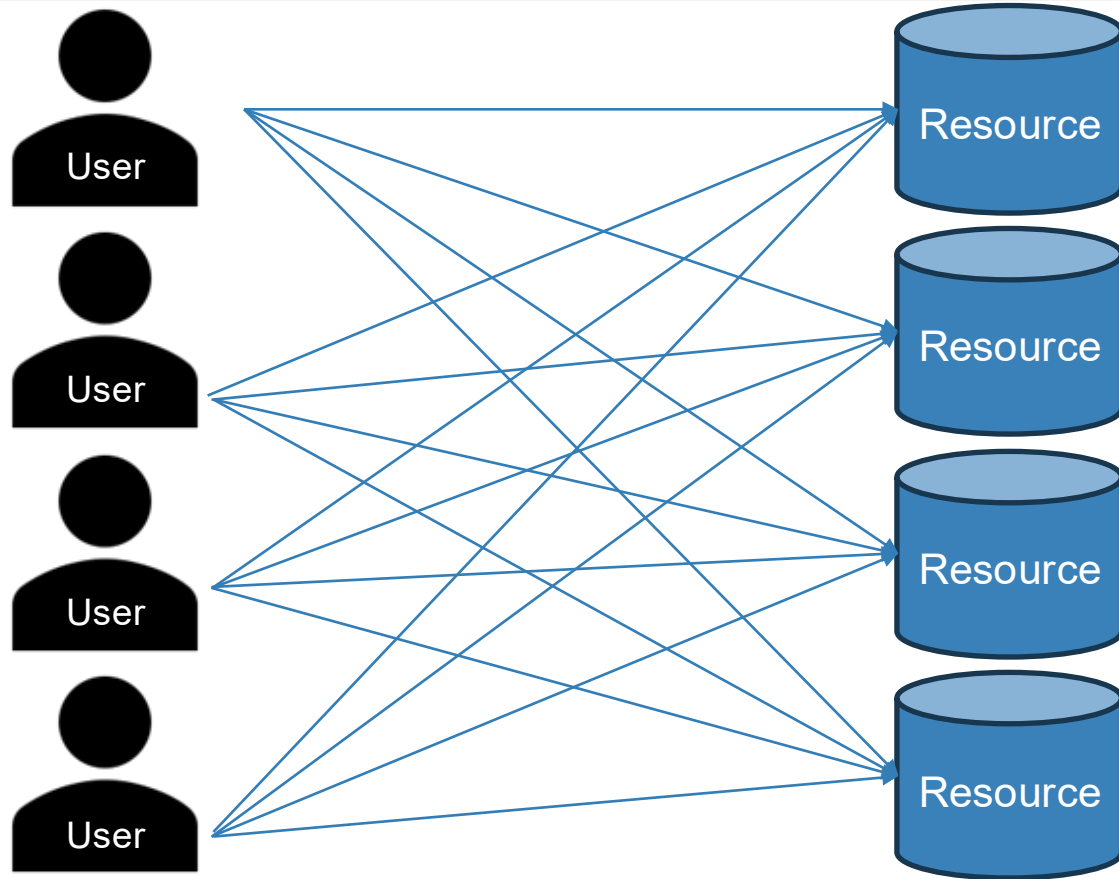
Other Security Settings:

- Admins can enforce minimum password length and complexity and prevent password reuse (password history). In enterprise environments, multi-factor authentication is often added for extra security (beyond just the Windows password).

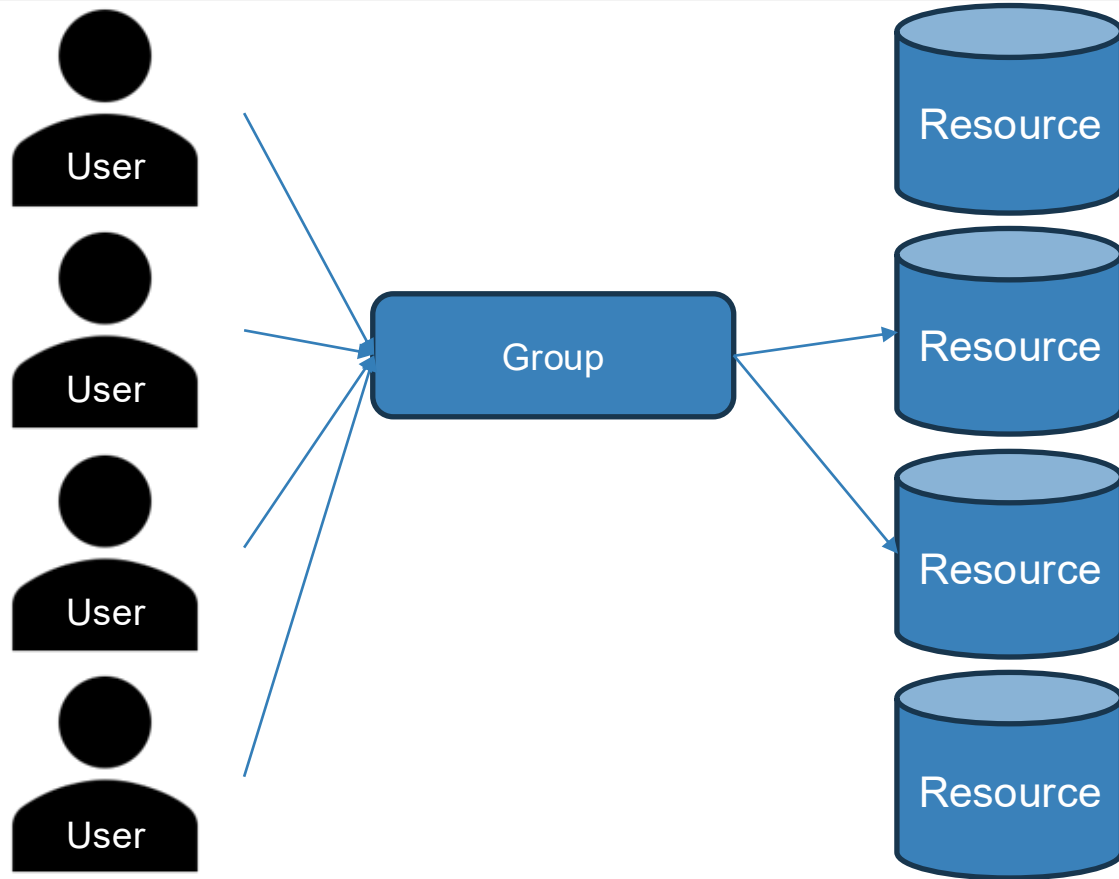
Permission Fundamentals



Permission Fundamentals



Permission Fundamentals



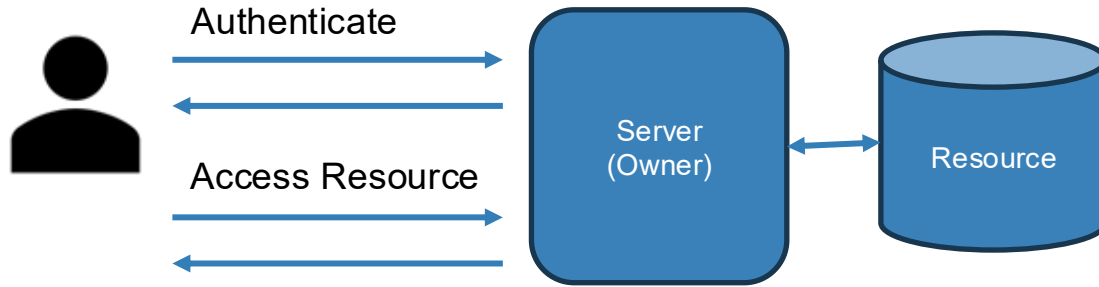
Demo

Active Directory Basics



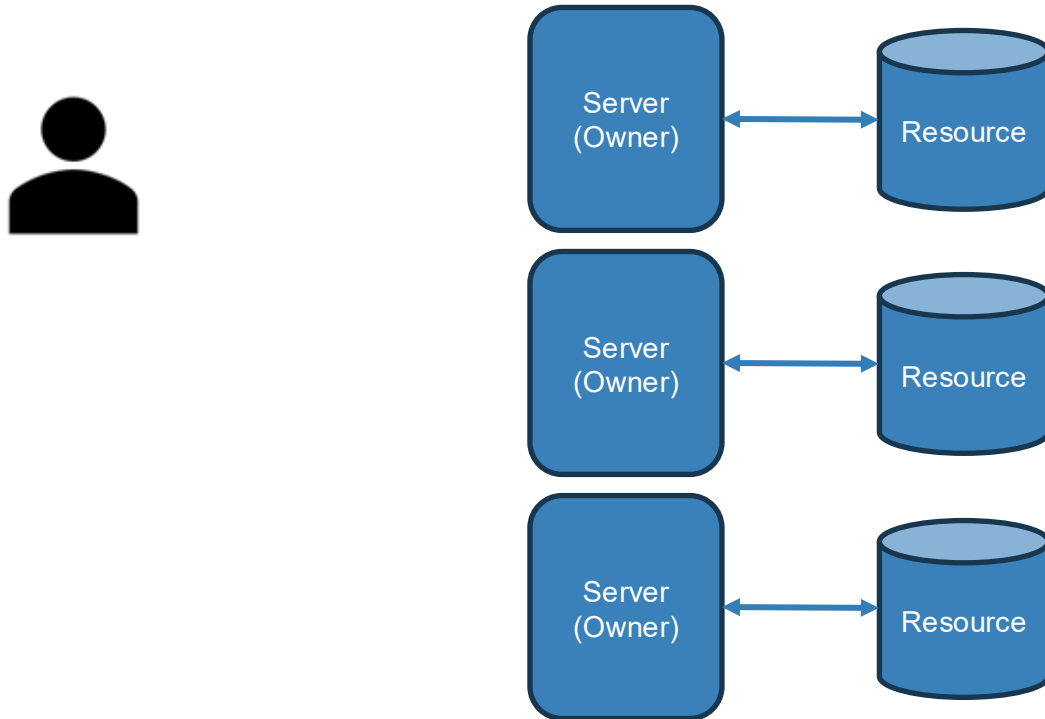
Active Directory

Local Identity and Access Management



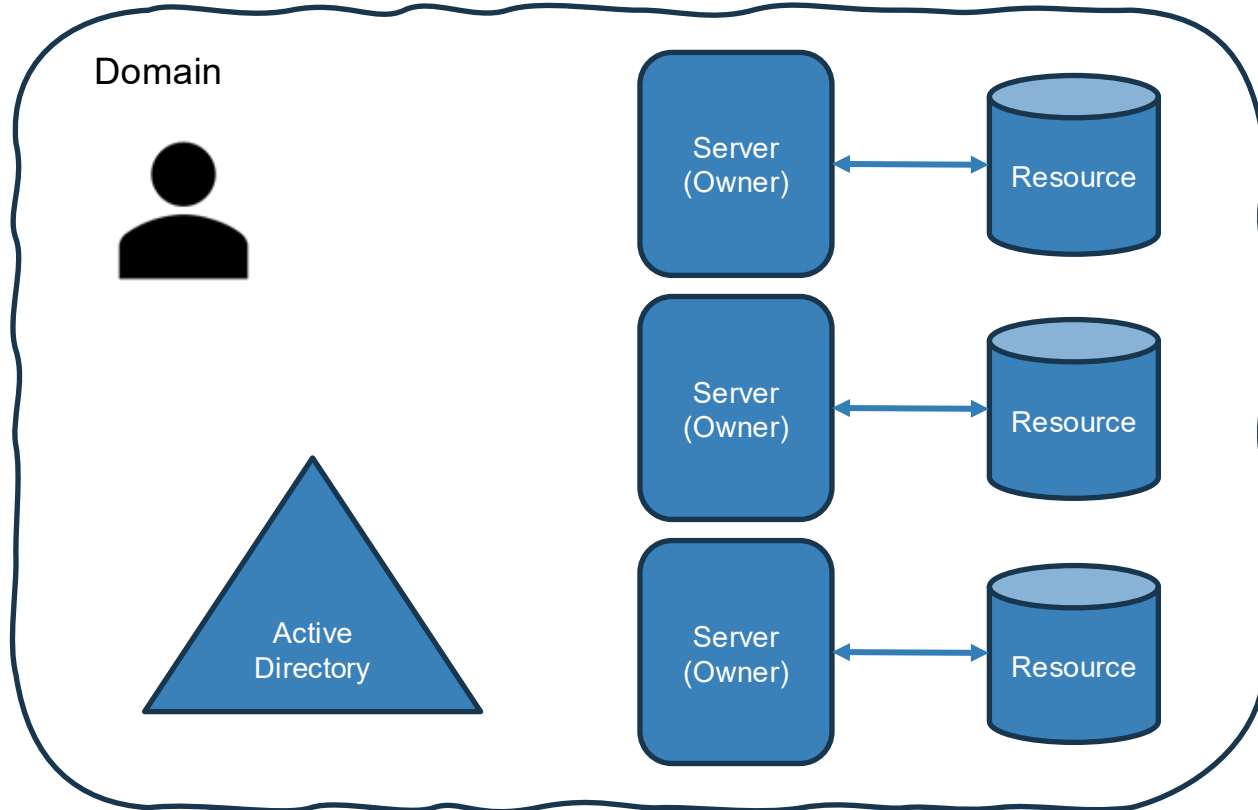
Active Directory

Local Identity and Access Management



Active Directory

Centralized Authentication and Identity Management



Demo

Windows Command Line Essentials



Command Prompt and PowerShell

- + Command Prompt (CMD): The original Windows command-line interface. Allows you run simple text commands and batch scripts for file management, network pings, etc. It's useful for basic scripting and troubleshooting.
- + PowerShell: A more advanced command-line and scripting environment. It uses cmdlets (special commands) to control Windows settings and automate tasks, and it can leverage the .NET framework for powerful scripts. Widely used by administrators for system management.
- + When to Use: CLI tools are useful for automation, bulk operations, or when a GUI isn't available. For example, you might use PowerShell to create multiple user accounts at once or to quickly retrieve system information that would be tedious to click through in the GUI.
- + Running as Administrator: Some commands (like editing system files or settings) require elevated privileges. You can launch CMD or PowerShell as admin (right-click and choose "Run as administrator") to execute those commands.

Basic Windows Command Prompt Commands

- + dir – Lists contents of a directory.
- + cd – Changes the current working directory.
- + copy – Copies files from one location to another.
- + move – Moves or renames files and directories.
- + These commands are text-based and suited for simple tasks.

```
C:\Users>dir C:\
Volume in drive C is Windows
Volume Serial Number is 0887-04E0

Directory of C:\

11/26/2013  08:53 PM                678,584 CMTrace.exe
12/21/2022  06:02 PM          <DIR>          EFI
01/15/2021  06:30 PM          <DIR>          Intel
12/07/2019  10:14 AM          <DIR>          PerfLogs
12/21/2022  06:36 AM          <DIR>          Program Files
11/21/2022  11:44 AM          <DIR>          Program Files (x86)
05/23/2022  08:09 AM          <DIR>          Snagit
05/09/2022  01:35 PM          <DIR>          Users
12/31/2022  01:07 PM          <DIR>          Windows

               1 File(s)                678,584 bytes
               8 Dir(s)  172,534,497,280 bytes free
```



PowerShell for Advanced Administration

1

Powerful Object-based
CLI

2

System Administration
and Automation

3

Integration

Understanding PowerShell Cmdlets

Cmdlets

- PowerShell's core commands, following a verb-noun naming convention (e.g., Get-Process, Set-Item).

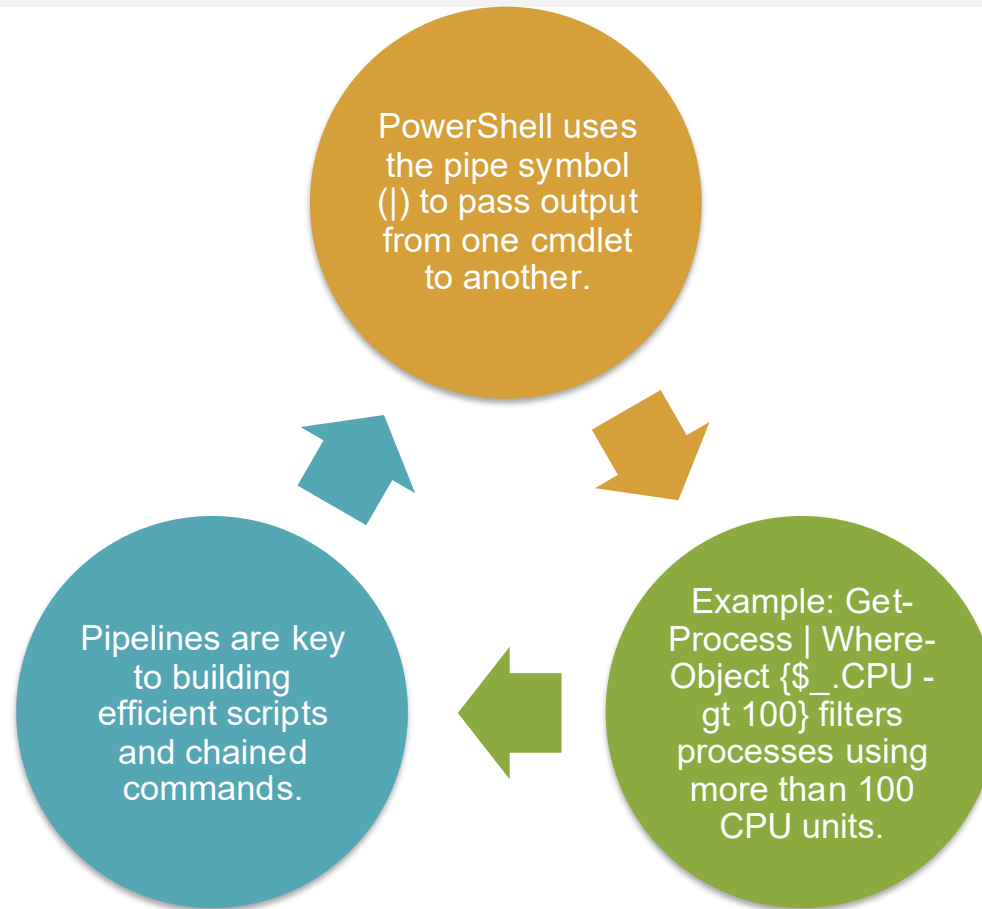
Get-Command, Get-Help

- Use Get-Command to discover available cmdlets and Get-Help <cmdlet> to read documentation.

Objects

- Cmdlets return objects that can be manipulated or passed into other cmdlets.

Using Pipelines in PowerShell



Demo

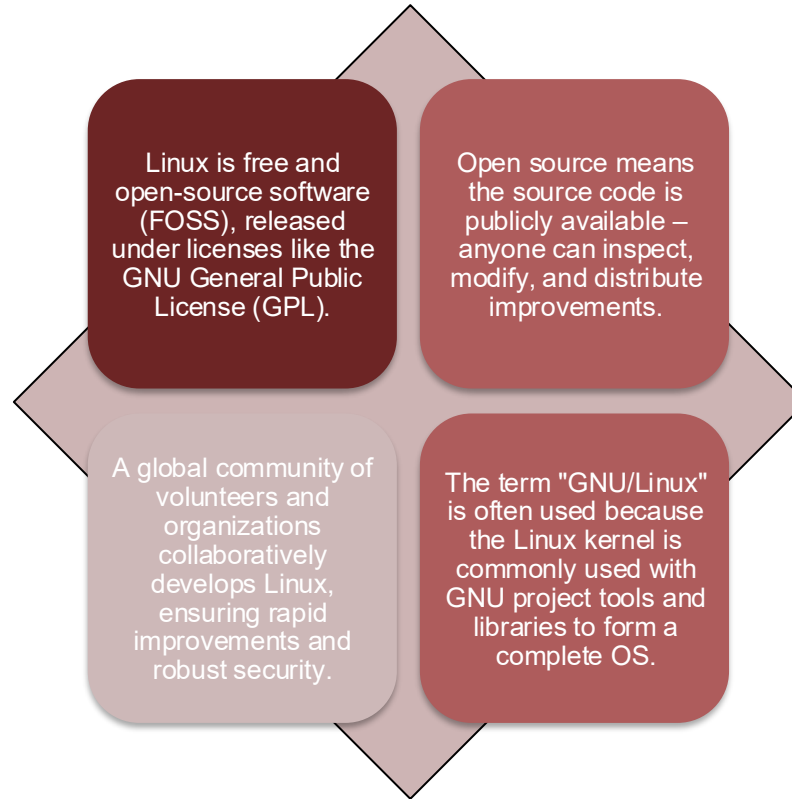
Linux Architecture



What is Linux?

- + Linux is an open-source operating system, similar to Unix, that runs on a wide range of devices.
- + It acts as a bridge between computer hardware and applications, managing resources and enabling software to run.
- + Known for its stability and security, Linux powers servers, desktops, smartphones (Android), and embedded systems.

Open Source and the Linux Community



Linux Distributions (Distros)

A distribution is a packaged version of Linux



There are hundreds of distros tailored for different needs



All distros share the Linux kernel at their core



Choice of distro depends on requirements

Linux Architecture Overview

Hardware

Kernel

System Libraries & Utilities

Shell

User Applications

A Word About Shells

- + Multiple Shells can run on the same OS (core)
- + Common Shells
 - + sh – basic, compatible with UNIX, often runs scripts (/bin/sh)
 - + bash – most common, used by Ubuntu and others
 - + zsh – similar to bash with more features, default on most MacOS machines
- + GUI
 - + Runs on top of shell
 - + Components include display server, desktop environment (GNOME), windows manager, GUI applications

Package Management Basics

Linux uses package managers to install, update, and remove software.



Different distributions use different packaging systems.

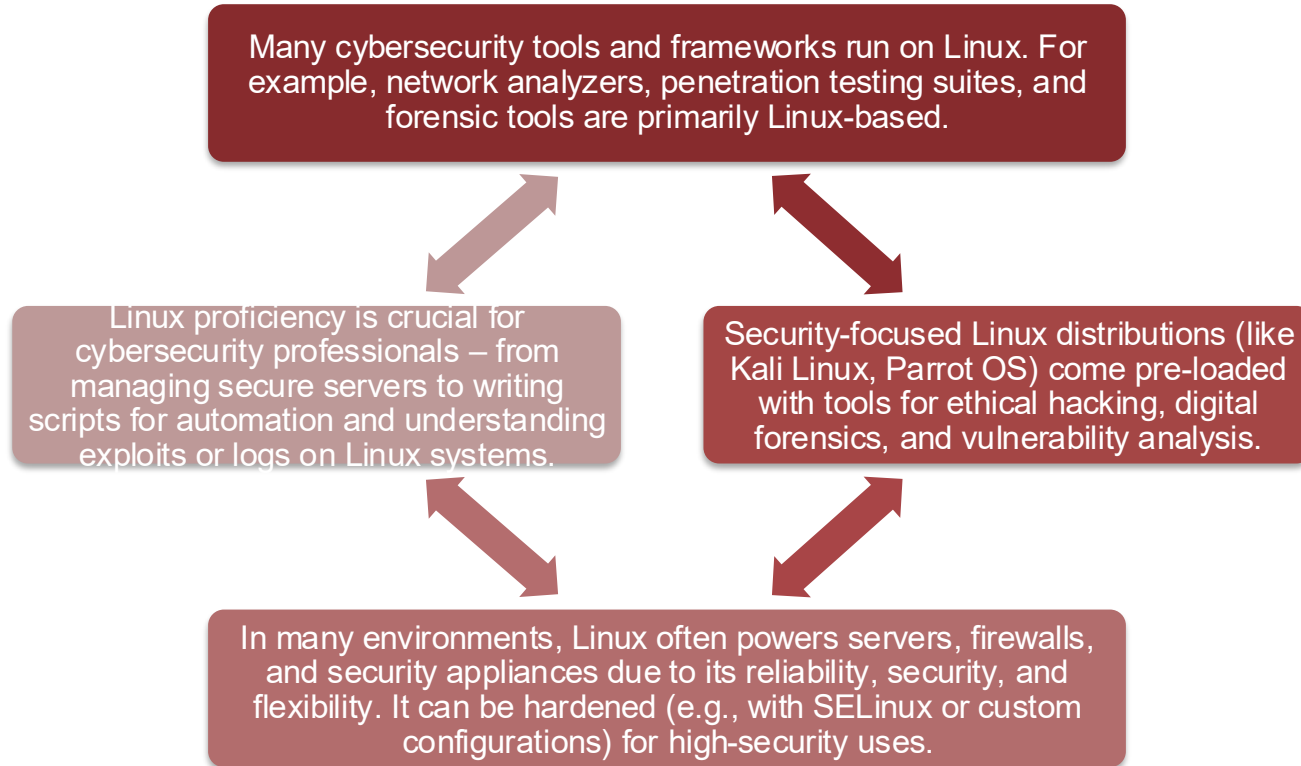


```
sudo apt update  
sudo apt install nmap.  
sudo yum install nano.
```



Package managers allow easy updates.

Linux in Cybersecurity

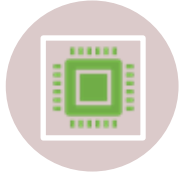


Demo

Linux Users, Groups, and File Permissions



Users and Groups in Linux



Linux is a multi-user system: many users can have accounts on one machine, each with isolated data and permissions.



Group: A collection of user accounts. Groups simplify permission management by allowing access rights to be shared among members. Each user can belong to one or more groups.



User: Each person or service has a user account (with a username and unique user ID). Regular users have limited privileges; the root user is the administrative account with full control.



Every file is owned by a user and a group. Users other than the owner might need to be in the file's group to have certain permissions (if allowed for group).

File Permissions Explained

Linux permissions control who can read, write, or execute a file or directory. This is fundamental for system security.

Permissions are defined for three categories: the owner (user who owns the file), the group (users in the file's group), and others (everyone else).

Three permission types: read (r) – view file contents or list directory, write (w) – modify file or directory contents, execute (x) – run a file as a program or enter a directory.

Example: `-rwxr-x--x` (from `ls -l`) indicates a file where the owner has `rwx` (read/write/execute), the group has `r-x` (read/execute), and others have `--x` (only execute). A `"-"` means that permission is not granted.

Changing Permissions and Ownership

- + `chmod`:
 - + Changes a file or directory's permissions. Use symbolic mode (e.g., `chmod u+x script.sh` to add execute for owner) or octal mode (e.g., `chmod 755 script.sh` sets `rw` for owner, `r-x` for group, `r-x` for others).
- + `chown`:
 - + Changes file ownership (and optionally group). Syntax: `chown <new_owner>:<new_group> <file>`. E.g., `sudo chown alice:developers project/` makes user 'alice' the owner of "project" and assigns it to group 'developers'.
- + `chgrp`:
 - + Changes the group ownership of a file or directory. E.g., `sudo chgrp developers project/file.txt` (can also be done via `chown` by specifying just `:group`).
- + Only the file's owner or the root user can change permissions or ownership. Regular users use `sudo` to run these commands if they need to modify system files or files they don't own.

Using sudo for Privileged Commands

`sudo`
("superuser do"): Allows a permitted user to execute a command as the superuser (root) or another user, as specified by the system's security policy.



When you run a command with `sudo`, it prompts for your password (to confirm identity) and then executes the command with elevated privileges. This is logged for security auditing.



Administrators give users `sudo` access (via `/etc/sudoers` file or group membership) instead of sharing the root password. This enables controlled privilege escalation.



Example: `sudo apt install nginx` will install a software package using root privileges. Use `sudo` carefully—commands run as root can affect the entire system.

Demo

Linux Processes & Services



Linux Processes



```
student@demoubuntu:~$ ps -aux
```

USER	PID	%CPU	%MEM	VSZ	RSS	TTY	STAT	START	TIME	COMMAND
root	1	0.0	0.3	167672	12892	?	Ss	15:49	0:02	/sbin/init
root	2	0.0	0.0	0	0	?	S	15:49	0:00	[kthreadd]

Process Management Tools

ps

- ps aux shows all running processes

top

- Displays running processes live, updating continuously.

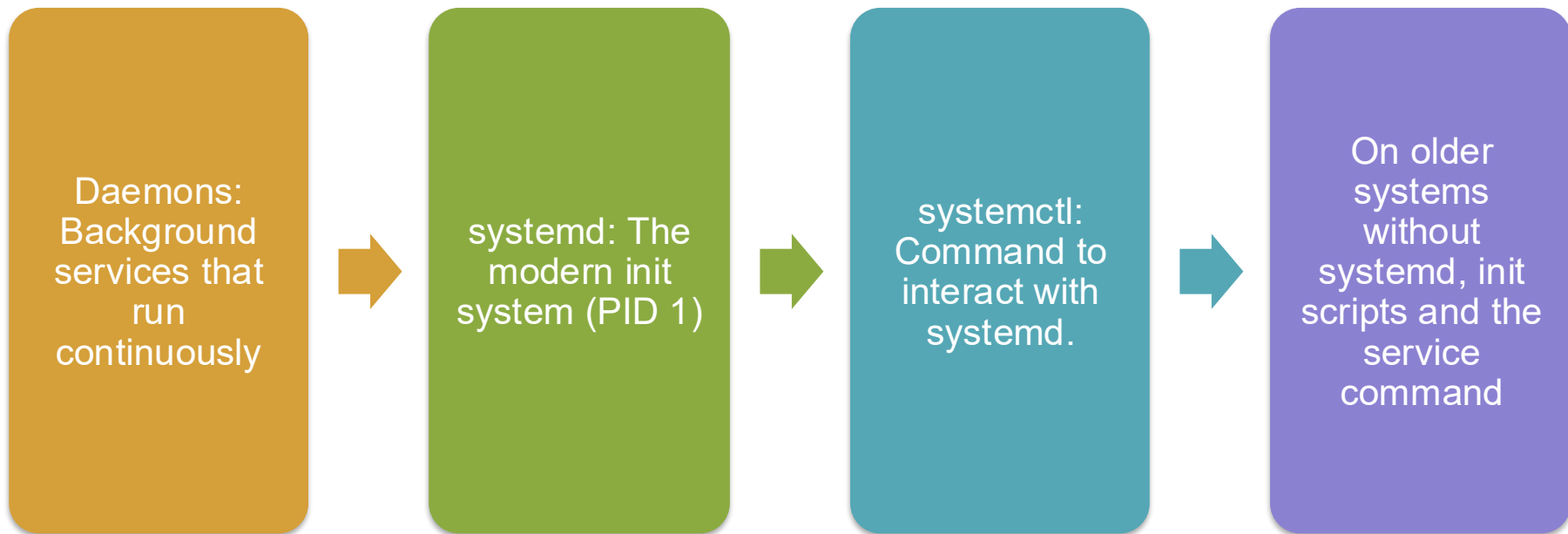
Jobs, fg, bg

- jobs lists background jobs. fg %1 brings job 1 to foreground; bg %1 resumes it in background.

kill

- Sends a signal to a process by PID to terminate it.

Services and Daemons



Why Linux Daemons Matters to a SOC Analyst

- + Processes show what is running right now
- + Services (daemons) show what is designed to run automatically
- + Both are key to detecting:
 - + Malware
 - + Persistence
 - + Unauthorized access
 - + Misconfigurations

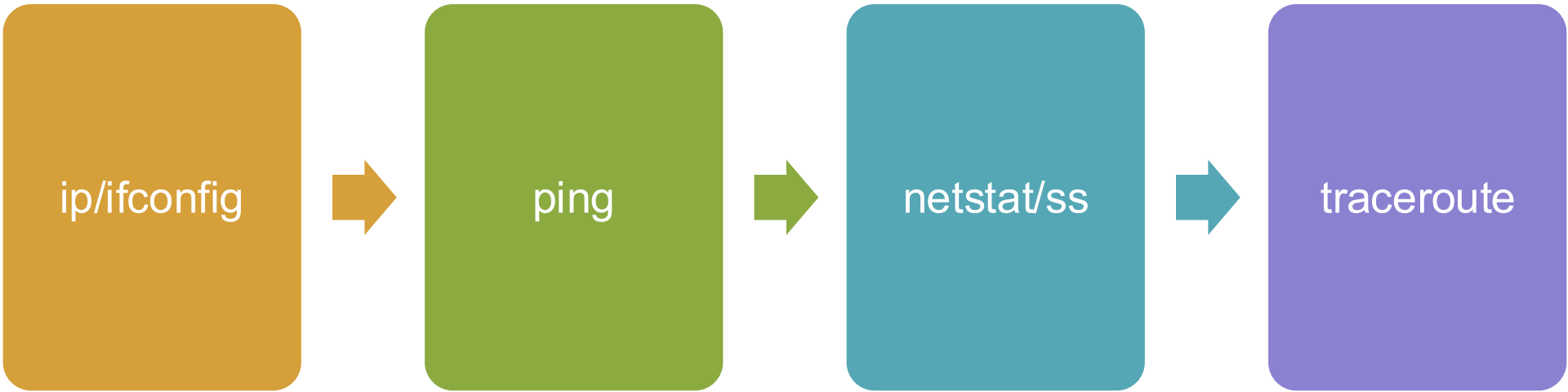
If you can't explain what a process or service is doing, you can't tell whether it's legitimate or malicious.

Demo

Linux Networking and Remote Access



Basic Networking Tools



Remote Access with SSH



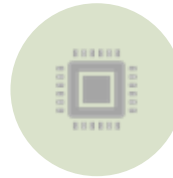
SSH (Secure Shell): The standard tool/protocol for secure remote login to Linux systems. It encrypts the session to protect data in transit.



Using SSH: `ssh <user>@<hostname>` lets you log into a remote Linux machine's shell (must have an SSH server running on the remote side, default port 22).



SSH uses key-based authentication or passwords. For better security, many admins use SSH key pairs (public/private keys) instead of passwords to authenticate without exposing credentials.



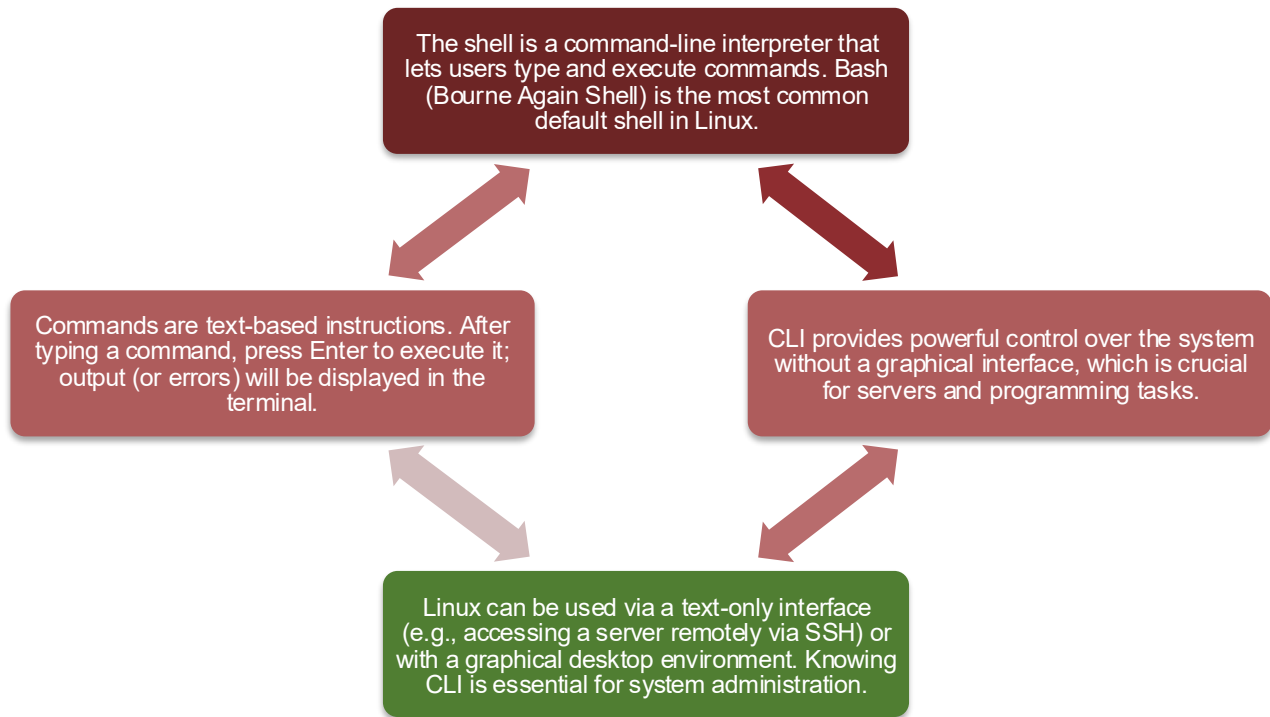
SSH also enables secure file transfer (using `scp` or `sftp`) and tunneling of other protocols securely through an SSH connection.

Demo

Linux Command Line Essentials



The Shell and Command Line Interface (CLI)



Basic Command Syntax and Getting Help



General syntax: `<command>` `[options]` `[arguments]`. For example, `"ls -l /etc"` where `ls` is the command, `-l` is an option (long format), and `/etc` is an argument (the directory to list).



Most commands have manual pages. Use the `man` command to read them (e.g., `"man ls"` shows the manual for the `ls` command).



Almost all commands support a `"--help"` or `"-h"` option to display a brief usage guide (e.g., `"ls --help"`).



Tab completion: Pressing Tab while typing a command or filename auto-completes it, saving time and avoiding typos.

File Paths and Navigation

Absolute path:

- /etc/hosts

Relative path:

- Documents/data.csv

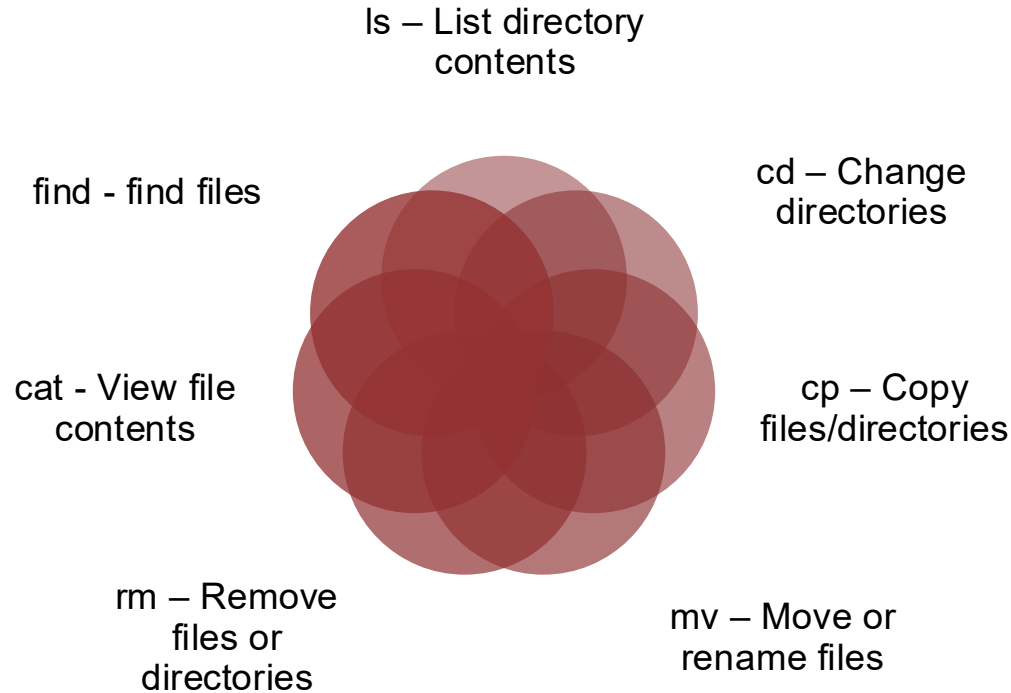
Special notations:

- . – Current
- .. – Parent
- ~ - User
- home

Use pwd

- Print Working Directory
- current
- folder

Common Linux Shell Commands



Redirection and Piping in Linux

> writes output to a file
(overwrites),
>> appends output,
< reads input from a file.

Pipe (|) sends output
from one command
into another.

Example:
`ps aux | grep ssh.`

Combine these tools
for powerful
automation and
filtering.

Linux vs. Windows Command Equivalents

dir (Windows)
≈
ls (Linux)

copy ≈ cp
move ≈ mv
del ≈ rm

ipconfig ≈
ifconfig or ip
addr

netstat works
similarly on
both
platforms

Demo

Thinking Like an Analyst



What Does It Mean to Think Like an Analyst?

- + Approaching problems with a **curious, investigative mindset**
- + Using **evidence-based reasoning** instead of assumptions
- + Understanding that alerts are **symptoms**, not conclusions
- + Identifying patterns, anomalies, and relationships in data

Key Traits of an Effective Analyst



Curiosity

- Always asking "Why?" or "What else could this mean?"



Skepticism

- Not taking data at face value



Attention to Detail

- Small clues often lead to big findings



Persistence

- Following evidence even when it's tedious



Objectivity

- Avoiding bias and assumptions

Basic Analytical Process

Observe

Question

Hypothesize

Investigate

Conclude &
Act

Using Context

Raw data $\neq$ insight.

Who?

- Was this a user? Admin? Service account?

Where?

- Was this internal? External? On a sensitive system?

When?

- Was this during business hours or at an unusual time?

What?

- Is this normal behavior for this user/system?

Context transforms:

- + “Login from new location” →
 - + Low risk (VPN pop, traveling user) or
 - + High risk (account takeover indicators)

Thinking in Attack Stages

Reconnaissance	• The attacker gathers information about the target.
Weaponization	• The attacker creates or prepares the malicious payload.
Delivery	• The attacker transmits the weapon to the victim.
Exploitation	• The malicious payload triggers and takes advantage of a vulnerability.
Installation	• Malware installs a persistent presence on the target system.
Command and Control (C2)	• The compromised system establishes communication with the attacker.
Actions on Objectives	• The attacker achieves their final goal.

The is based on the Cyber Kill-chain developed by Lockheed Martin
<https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>

Correlating Data

Analysts don't rely on one log source.

Combine:

- + Firewall events
- + Endpoint alerts
- + Authentication logs
- + Threat intelligence

Correlation helps identify:

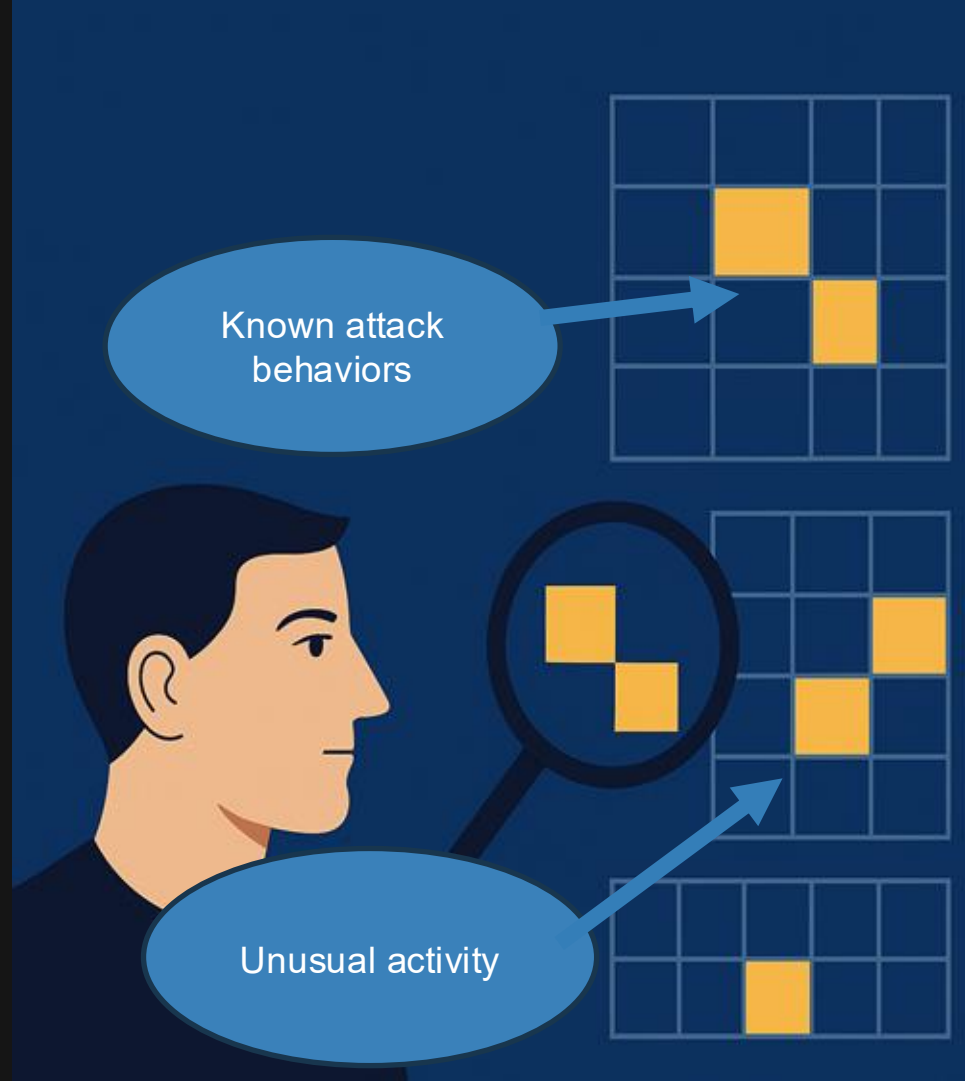
- + Multi-stage attacks
- + True vs false positives

Only go “as deep as needed” — avoid over-investigating low-risk events.

Pattern Recognition



Pattern Recognition Basics



Types of Patterns Analysts Look For

Patterns

Behavioral

- Repeated failed logins
- Consistent remote access at odd hours
- Unusual PowerShell usage

Technical

- Known malware behaviors
- Common attacker TTPs (MITRE ATT&CK)
- Repeated ports/IPs associated with scanning

Temporal

- Events happening at the same time every night
- Activity spikes during weekends or holidays

Pattern Recognition Techniques

- + Deliberate comparison
- + Chunking
- + Hypothesis-driven thinking
- + Slow then fast thinking

Pattern Recognition Exercises

- + What's normal?
- + Log review without labels
- + Reverse analysis
- + Daily analysis
 - + 1 phishing report
 - + 1 malware report

Real-World Example

Activity A

User: j.smith

Time Window: 07:50–08:30

- 2 failed authentication attempts
- Successful login from IP 198.51.100.24
- Login from new IP address
- MFA challenge approved
- Browser-based login
- Accessed:
 - Email
 - File share
 - Internal documentation
- Session duration: ~38 minutes
- No additional authentication events

Activity B

User: j.smith

Time Window 21:40–22:05

- 4 failed authentication attempts
- Successful login from IP 203.0.113.77
- Login from same country as prior logins
- MFA challenge approved
- Browser-based login
- Accessed:
 - Email
 - HR portal
 - Account security settings
- Session duration: ~22 minutes
- Second login attempt from different IP 9 minutes later (successful)

Avoiding Analytical Bias



What is Analytical Bias?

- + “*Systematic errors in judgment rooted in mental shortcuts or heuristics.*” – MITRE CTI Handbook
- + SOC analysts work with incomplete or ambiguous data
- + Bias can cause:
 - + Wrong severity assignment
 - + Incorrect escalation
 - + Dismissing real threats
 - + Chasing false leads
- + Bias directly affects detection quality.

Common Bias #1: Confirmation Bias

- + **Definition:** Searching for evidence that supports your existing belief while ignoring contradictory data.
- + **Example:**
Alert says “possible malware.”
Analyst only looks for malware indicators and ignores signs of normal activity.
- + **Countermeasure:**
Ask: “*What evidence contradicts my assumption?*”

Common Bias #2: Anchoring

- + **Definition:** Fixating on the first piece of information you see.
- + **Example:**
Seeing “User mistyped password” leads analyst to assume login failures are benign—even when later logs suggest brute force.
- + **Countermeasure:**
Pause and re-evaluate once more data comes in.

Common Bias #3: Normalcy Bias

- + **Definition:** Assuming activity is harmless because it seems routine or because “it hasn’t happened before.”
- + **Example:** Ignoring unusual traffic because “that server always generates noise.”
- + **Countermeasure:** Compare with baselines; don’t rely on comfort or familiarity.

Common Bias #4: Availability Bias

- + **Definition:** Relying on what's top-of-mind or most memorable.
- + **Example:**
Recently saw a phishing case → treat every email-related alert as phishing without proper validation.
- + **Countermeasure:**
Use structured investigation steps, not memory alone.

Mini Case Study: How Bias Misleads

Scenario:

You see:

- + Failed logins
- + Followed by a successful one
- + From an unusual location

Biased thinking:

- + “User probably forgot password” (normalcy bias)
- + “This is usually a false positive” (availability bias)

Objective thinking:

- + Validate IP reputation
- + Check login history
- + Look for additional suspicious behavior

Bias = misses account compromise

Objective analysis = potential incident caught



Communicate Without Bias

- + Document only facts
- + Avoid assumptions in notes
- + Clearly distinguish between:
 - + Observations
 - + Analysis
 - + Conclusions
- + Ask a peer to review when unsure
- + Clear writing helps separate fact from interpretation.

Staying Current in Cybersecurity



Why Staying Current Matters

Cybersecurity changes **daily**:

- + New vulnerabilities
- + New attacker techniques
- + New tools and defenses
- + Evolving regulations and technologies

SOC analysts must stay up to date to detect, interpret, and respond to modern threats accurately.

The Threat Landscape Changes Constantly



**CLOUD AND SAAS
ATTACK VECTORS**



RANSOMWARE



**NEW PHISHING AND
SOCIAL ENGINEERING
TACTICS**

What SOC Analysts Need to Stay Current On

- + Attack techniques (TTPs, MITRE ATT&CK updates)
- + New vulnerabilities & patches
- + Threat intelligence trends
- + Changes in systems and environments you defend
- + Security tools (EDR, SIEM, threat intel platforms)
- + Industry news and major incidents

You don't need to know *everything*—just what's relevant to your environment.

Recommended Information Sources

Free Sources

- + CISA Alerts & Advisories
- + US-CERT / NCSC updates
- + MITRE ATT&CK changes
- + BleepingComputer, KrebsOnSecurity
- + Vendor blogs (Microsoft, Cisco, CrowdStrike, SentinelOne)

Internal Sources

- + IR team briefings
- + Internal threat intel feeds
- + Post-incident reviews

A Short List of Resources

- + <https://dfircommunity.slack.com/>
- + <https://www.reddit.com/r/netsecstudents/>
- + <https://feeds.feedburner.com/TheHackersNews>
- + <https://www.darkreading.com/rss.xml>
- + <https://news.sophos.com/en-us/feed/>
- + <https://krebsonsecurity.com/>
- + <https://threatfeeds.io/>
- + <https://github.com/threat-hunting/awesome-threat-intelligence>
- + <https://infragard.fbi.gov/>
- + <https://abuse.ch/>
- + <https://www.talosintelligence.com/>
- + <https://virusshare.com/>
- + <https://twitter.com/TheDFIRReport>
- + <https://discord.com/invite/25wHxrsspd>
- + <https://x.com/DarkWebInformer>
- + <https://socprime.com/blog/>

Participating in the Security Community

Ways to stay engaged:

- + Join security Slack/Discord groups
- + Follow trusted researchers on LinkedIn or Twitter/X
- + Attend webinars and vendor briefings
- + Participate in local security meetups (e.g., OWASP chapters)

Community input accelerates learning—fast.

Build Continuous Learning Habits

Daily (5–10 mins):

- + Scan headlines, bulletins, or alerts
- + Review internal dashboards

Weekly:

- + Read 1–2 threat reports
- + Watch a short training or webinar
- + Review major incidents and lessons learned

Monthly:

- + Take a short course
- + Update your knowledge of tools or logs
- + Consistency beats intensity.



Introduction to Compliance and Legal Responsibilities



What Is Compliance?

Following laws, regulations, standards, and internal policies that govern how an organization operates.

Compliance ensures:

- + Proper handling of sensitive information
- + Adherence to legal obligations
- + Alignment with industry best practices

Why Compliance Matters

- + Builds customer and stakeholder trust
- + Ensures protection of sensitive data
- + Reduces organizational risk
- + SOC analysts play a key role in maintaining compliance through monitoring and reporting

Key Compliance Drivers



Regulatory Requirements



Industry Standards



Contractual Obligations



Internal Policies

What Are Legal Responsibilities?

Actions an organization is legally required to take to protect data, systems, and users.

These include:

- + Protecting customer data
- + Reporting certain breaches
- + Following cybersecurity and privacy laws
- + Ensuring proper access control

Common Laws and Regulations

GDPR (EU)

- Protects personal data of EU citizens
- Requires breach notification within 72 hours

HIPAA (USA)

- Protects healthcare data
- Requires strict access control and auditing

SOX (USA)

- Ensures accuracy of financial reporting
- Requires controls over financial systems

PCI-DSS*

- Ensures accuracy of financial reporting
- Requires controls over financial systems

SOC Analyst Responsibilities in Compliance



Monitoring & Detection

- Identifying policy violations
- Detecting unauthorized access
- Watching for data exfiltration indicators



Documentation

- Maintaining clear, accurate investigation notes
- Recording evidence for audits



Reporting

- Escalating incidents that may violate laws or standards
- Supporting legal and compliance teams during investigations

Privacy



What Is Privacy?

The right of individuals to control how their personal information is collected, used, stored, and shared.

- + Privacy focuses on:
 - + Protecting personal data
 - + Respecting user rights
 - + Preventing misuse of information
- + **Why Privacy Matters**
 - + Builds trust with customers and employees
 - + Required by laws and regulations
 - + Helps prevent identity theft and fraud
 - + Reduces risk of reputational damage
- + SOC analysts encounter personal data regularly
- + Privacy is a **legal obligation** and an **ethical responsibility**.

Personal Data Examples

Personal data = any information that identifies a person.

Examples:

- + Name, address, phone number
- + Email address or IP address
- + Employee ID or badge number
- + Financial information
- + Health information
- + Login credentials
- + Behavioral data (logs, website activity)

SOC analysts must handle this data carefully.

Key Privacy Principles

1

Minimization

- Collect only what you need.

2

Purpose Limitation

- Use data only for its intended purpose.

3

Access Control

- Only authorized people should view personal data.

4

Transparency

- People should know how their data is used.

5

Protection

- Data must be secured from misuse or unauthorized access.

Privacy Laws to Know

- + **GDPR (EU)**
 - + Strict rules for handling personal data
 - + Requires breach notification
- + **CCPA/CPRA (California)**
 - + Gives consumers rights over their data
 - + Requires transparency and opt-out options
- + **HIPAA (U.S. healthcare)**
 - + Protects health information
- + **PCI-DSS**
 - + Protects payment card data
 - + These laws shape how organizations must protect data.

SOC Analyst Responsibilities

- + As a SOC Analyst, you must:
 - + Avoid unnecessary access to personal data
 - + Only view logs and records needed for investigations
 - + Report suspected data exposure immediately
 - + Never share sensitive data outside proper channels
 - + Keep investigation notes factual and free of unnecessary personal details
- + During an investigation, analysts should ask:
 - + Do I need this data to complete the investigation?
 - + Am I storing personal data in my notes unnecessarily?
 - + Could I use masked or anonymized data instead?
- + Good privacy practice reduces liability.

Best Practices

- + Follow internal privacy policies
- + Lock your workstation
- + Do not store personal data locally
- + Avoid discussing sensitive details outside approved channels
- + Treat all personal data as high-risk

Data Handling and Evidence Preservation



Why This Matters

- + SOC analysts often work with **sensitive data** and **potential evidence**
- + Improper handling can:
 - + Destroy evidence
 - + Compromise investigations
 - + Violate policy or law
 - + Lead to disciplinary or legal action
- + Good evidence handling protects the organization

What Counts as “Evidence”?

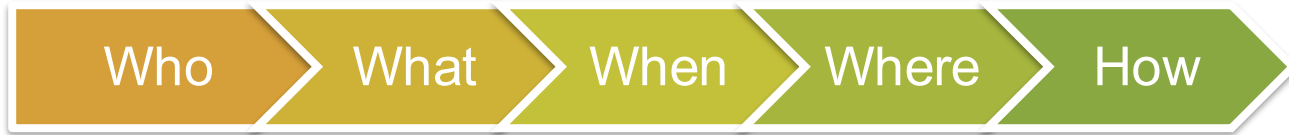
- + Evidence includes any data that may be used in:
 - + Security investigations
 - + Incident response
 - + Legal or regulatory matters
- + Examples:
 - + Log files
 - + Alert details
 - + Network traffic captures
 - + Email headers or samples
 - + Endpoint telemetry
 - + Screenshots
 - + System artifacts

If it helps explain *what happened*, it's evidence.

Key Principle: Integrity

- + Evidence must be:
 - + Accurate
 - + Unaltered
 - + Complete
- + Analysts must avoid:
 - + Modifying timestamps
 - + Editing log files
 - + Changing system states
 - + Deleting or overwriting items
- + If integrity is lost → evidence becomes **unreliable**.

Chain of Custody



As a SOC L1, you may not manage chain-of-custody forms—but you must handle data in a way that preserves it **if** needed.

Do's and Don'ts of Evidence Handling

Do's of Evidence Handling

- Collect data **as soon as possible**
- Preserve original logs where feasible
- Take screenshots of volatile data
- Export logs without modification
- Use approved tools and storage locations
- Document what you found and how you found it

Don'ts of Evidence Handling

- Don't alter or delete logs
- Don't copy evidence to personal devices
- Don't share screenshots or data over unapproved channels
- Don't "clean up" systems before IR reviews them
- Don't perform actions outside approved scope

Handling Evidence

Log Evidence	Endpoint & Network Evidence	Volatile Evidence
• Log data is a primary evidence source. • Export logs in read-only formats (CSV, JSON, text) • Note the time range collected • Preserve time zone and timestamps • Avoid filtering too early—collect broadly, analyze narrowly • Document search queries used during export • Logs must reflect exactly what happened.	• Avoid running unapproved commands on a compromised host • Avoid rebooting systems showing suspicious behavior • Avoid isolating a machine unless instructed • Refer collection tasks to senior analysts or IR team when needed • Your primary job is to observe, document, and escalate.	• RAM contents • Running processes • Active network connections • Logged-in sessions • Temporary files • If you see volatile indicators: • Capture screenshots • Document timestamps • Notify IR immediately • Every second counts.

Example Scenario

- + **Alert:** Possible malware execution on a workstation.
- + Good L1 analyst actions:
 - + Validate alert details → check EDR & logs
 - + Capture screenshots of suspicious process
 - + Export relevant logs without filtering
 - + Document everything observed
 - + Do **not** reboot or quarantine unless policy says so
 - + Escalate to incident response

This preserves evidence for expert analysis.

DEMO

Ethical Use of Tools and Information



Why Ethics Matter in Cybersecurity

- + SOC analysts have access to sensitive tools and data
- + Ethical behavior protects:
 - + The organization
 - + Customers and employees
 - + The integrity of investigations
 - + Your personal professional reputation
- + Misuse of tools or data can cause **legal, financial, and career-ending** consequences



What “Ethical Use” Means

*Using security tools and
information only for
authorized, legitimate
organizational purposes.*

SOC Analyst Access Is Powerful

- + As an analyst, you may access:
 - + Logs showing user behavior
 - + Emails or message metadata
 - + System and account information
 - + Endpoint and network monitoring tools
 - + Vulnerability and configuration data
- + This access must be treated with **caution and responsibility**.

Ethical Boundaries

- + Analysts must **not**:
 - + Use tools to view private data out of curiosity
 - + Investigate coworkers or individuals without authorization
 - + Access systems or logs unrelated to assigned work
 - + Search for “interesting” data without cause
 - + Share sensitive information outside proper channels
- + Good analysts stay within defined scope.

Privacy & Least Privilege

+ Privacy

- + Handle information carefully:
- + Avoid unnecessary exposure
- + Only view data required for the task
- + Never copy or store personal data locally

+ Least Privilege

- + Access only what is needed
- + Use elevated privileges only when required

These principles protect both people and the organization.

Ethical Use of Security Tools

- + Examples of proper tool use:
 - + SIEM queries → only for assigned alerts
 - + EDR investigations → only when investigating suspicious activity
 - + Packet captures → only when authorized
 - + Vulnerability tools → only for approved scanning targets

Tools are powerful — misuse can cause outages, privacy violations, or legal risk.

Handling Sensitive Information

- + Keep investigation data confidential
- + Use approved communication channels
- + Protect data at rest and in transit
- + Avoid discussing incidents with unauthorized staff
- + Follow policy for storage, sharing, and retention
- + Think: **“Would this be acceptable during an audit?”**

Conflicts of Interest

- + Examples:
 - + Investigating a system or person you have a personal relationship with
 - + Using access to gather information for non-work reasons
 - + Using information to gain advantage inside or outside the company
- + If a conflict exists:
 - + Disclose it
 - + Ask for reassignment
- + Transparency builds trust.

Reporting Ethical Concerns

- + If you see:
 - + Tool misuse
 - + Unauthorized access
 - + Policy violations
 - + Privacy breaches
- + You must:
 - + Report immediately to leadership, compliance, or security management
 - + Do *not* confront individuals directly
 - + Follow organizational reporting channels
- + Ethical environments rely on accountability.

Decision-Making Framework

- + Before taking any action, ask:
- + Is this within my authorized role?
- + Does policy allow this?
- + Is this necessary for the investigation?
- + Could this harm someone's privacy?
- + Would I be comfortable explaining this to leadership?
- + If uncertain: Stop and ask.

Best Practices

- + Follow organizational policies and the SOC playbook
- + Access only what you need
- + Use secure communication methods
- + Keep professional boundaries
- + Protect sensitive information
- + Report concerns promptly

Ethics is part of being a trusted professional.

Reporting and Documentation Standards



Why Documentation Matters

- + Strong documentation:
 - + Ensures investigations are **repeatable and traceable**
 - + Supports escalation and handoffs
 - + Creates a legal and audit-ready record
 - + Helps leadership make informed decisions
 - + Improves SOC efficiency and accuracy
- + If it isn't documented, it didn't happen.

What Counts as Documentation?

- + SOC documentation includes:
 - + Investigation notes
 - + Timelines of events
 - + Evidence collected (logs, screenshots, queries)
 - + Escalation summaries
 - + Incident reports
 - + Ticket updates and case notes
- + All documentation must be **accurate, complete, and clear**.

Core Principles of Good Documentation

- + **Accuracy**
 - + Record facts, not assumptions
- + **Clarity**
 - + Write simply and directly
- + **Completeness**
 - + Include everything needed to understand the investigation
- + **Consistency**
 - + Follow SOC templates and style
- + **Timeliness**
 - + Document as you go, not afterward
- + These principles ensure reliability and readability.

Writing Effective Investigation Notes

- + Good notes should include:
 - + What triggered the investigation
 - + What tools you used
 - + Commands or queries run
 - + Evidence found (and not found)
 - + Decisions made and why
 - + Time-stamped activity

Tip: Use bullet points for clarity.

Timelines: A Best Practice

- + Timelines help reconstruct events.
- + Include:
 - + Timestamps
 - + Event descriptions
 - + Source of the data (SIEM, firewall, EDR, etc.)
 - + Key findings or notable anomalies
- + Example:
 - + **02:15 UTC** – Successful login from unfamiliar IP
 - + **02:17 UTC** – PowerShell spawned by non-admin user
 - + **02:18 UTC** – Lateral movement attempt blocked
- + Timelines make escalation and IR handoff fast and effective.

Documentation Standards for Tickets

- + Every ticket should include:
 - + Clear title (what's happening)
 - + Description of alert or issue
 - + Step-by-step notes
 - + Evidence and queries used
 - + Final disposition (true positive, false positive, inconclusive)
 - + Who handled the case, and when
- + Tickets become **official records** used by auditors and leadership.

Confidentiality in Documentation

- + Analysts must ensure documentation:
 - + Contains only the data necessary
 - + Avoids unrelated personal information
 - + Does not disclose sensitive details in open channels
 - + Remains inside approved ticketing/systems
- + Documentation must comply with:
 - + Internal policy
 - + Privacy laws (GDPR, HIPAA, etc.)
 - + Evidence-handling rules

Best Practices for Consistency

- + SOC analysts should:
 - + Use standardized templates
 - + Follow naming conventions
 - + Maintain organized notes
 - + Write narratively but concisely
 - + Review notes before closing a case

Consistency builds SOC maturity.

Core Skills for SOC Analysts - Summary

KEY CONCEPTS - RECAP

- Information security foundations
- Network & system monitoring
- Log analysis & alert triage



LEARNING OUTCOMES - RECAP

- Interpret security events & alerts
- Understand enterprise networks & systems
- Apply analytical thinking in investigations
- Operate responsibly within legal & privacy boundaries

REAL-WORLD APPLICATIONS

- Supporting day-to-day SOC operations
- Investigating suspicious activity
- Documenting & escalating incidents

NEXT STEPS

- Practice with SIEM & log analysis tools
- Explore threat detection & incident response courses
- Continue building hands-on SOC experience

THANKS FOR WATCHING!



EXPERTS AT MAKING YOU AN EXPERT

